



กรมการท่องเที่ยว

แนวนโยบายและแนวปฏิบัติในการรักษาความมั่นคงปลอดภัย ด้านสารสนเทศของหน่วยงานรัฐ

วัตถุประสงค์

เอกสารนโยบายฉบับนี้จัดทำขึ้น เพื่อเป็นแนวทางในการดำเนินงานและแนวปฏิบัติ เพื่อเสริมสร้างความมั่นคงปลอดภัยของระบบสารสนเทศให้แก่องค์กร เพื่อให้สอดคล้องกับมาตรฐานระบบบริหารจัดการด้านความมั่นคงปลอดภัยสารสนเทศ (ISO ๒๗๐๐๑: Information Security Management System: ISMS) และตามมาตรา ๕ มาตรา ๖ และ มาตรา ๗ แห่งพระราชกฤษฎีกากำหนดหลักเกณฑ์และวิธีการในการทำธุรกรรมทางอิเล็กทรอนิกส์ภาครัฐ พ.ศ. ๒๕๔๙ โดยให้สอดคล้องกับสถานการณ์ในปัจจุบันและความต้องการของระบบ ตลอดจนความต้องการจากการใช้งานเชิงธุรกิจขององค์กร

โดยแนวนโยบายในการรักษาความมั่นคงปลอดภัยด้านสารสนเทศของหน่วยงานรัฐนี้ จัดทำขึ้นตามความร่วมมือด้านมาตรฐานระหว่างสำนักงานพัฒนาธุรกรรมอิเล็กทรอนิกส์ (องค์การมหาชน) กับ กรมการท่องเที่ยว ซึ่งตั้งอยู่ที่ ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐ อาคารรัฐประศาสนภักดี อาคาร B ศูนย์ราชการฯ แจ้งวัฒนะ เลขที่ ๑๒๐ หมู่ ๓ ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ ๑๐๒๑๐

เอกสารอ้างอิง

ISO/IEC	Information technology-Security techniques-Information
๒๗๐๐๑:๒๐๑๓	security management systems-Requirements
ISO/IEC	Information technology-Security techniques-Code of practice
๒๗๐๐๒:๒๐๑๓	for information security controls

สารบัญ

วัตถุประสงค์	๒
สารบัญ	๓
คำนิยาม	๖
นโยบายและแนวปฏิบัติในการรักษาความมั่นคงปลอดภัยสารสนเทศ (Information Security Policy and Procedure)	๑๐
๑. นโยบายความมั่นคงปลอดภัยสารสนเทศ (Information Security Policies)	๑๐
๒. โครงสร้างความมั่นคงปลอดภัยสารสนเทศ (Organization of Information Security)	๑๐
๓. ความมั่นคงปลอดภัยสำหรับทรัพยากรบุคคล(Human Resource Security)	๑๒
๓.๑ ก่อนการจ้างงาน (Prior to employment)	๑๒
๓.๒ ระหว่างการจ้างงาน (During employment)	๑๒
๓.๓ การสิ้นสุดหรือการเปลี่ยนแปลงการจ้างงาน (Termination and change of employment)	๑๒
๔. การบริหารจัดการสินทรัพย์ (Asset Management)	๑๓
๔.๑ หน้าที่ความรับผิดชอบต่อสินทรัพย์ (Responsibility for assets)	๑๓
๔.๒ การจัดประเภทของข้อมูลสารสนเทศ (Information classification)	๑๔
๔.๓ การจัดการสื่อบันทึกข้อมูล (Media Handling)	๑๕
๕. ความมั่นคงปลอดภัยทางกายภาพและสภาพแวดล้อม (Physical and environmental security)	๑๕
๕.๑ พื้นที่หวงห้าม (Secure areas)	๑๕
๕.๒ การรักษาความปลอดภัยอุปกรณ์ (Equipment security)	๑๖
๖. ความมั่นคงปลอดภัยสำหรับการดำเนินงาน (Operations security)	๑๘
๖.๑ ขั้นตอนการปฏิบัติงานและหน้าที่ความรับผิดชอบ (Operational procedure and responsibilities)	๑๘
๖.๒ การป้องกันซอฟต์แวร์ประสงค์ร้าย (Protection from malware)	๑๙
๖.๓ การสำรองข้อมูล (Backup)	๒๐
๖.๔ การบันทึกข้อมูลล็อกและการเฝ้าระวัง (Logging and monitoring)	๒๐
๖.๕ การควบคุมการติดตั้งซอฟต์แวร์บนระบบให้บริการ (Control of operational software)	๒๑
๖.๖ การบริหารจัดการช่องโหว่ทางเทคนิค (Technical vulnerability management)	๒๑
๖.๗ สิ่งที่ต้องพิจารณาในการตรวจสอบระบบ (Information systems audit considerations)	๒๑
๗. ความมั่นคงปลอดภัยสำหรับการสื่อสารข้อมูล (Communications security)	๒๒
๗.๑ การบริหารจัดการความมั่นคงปลอดภัยของเครือข่าย (Network security management)	๒๒
๗.๒ การถ่ายโอนสารสนเทศ	๒๒
๘. การจัดหา การพัฒนา และการบำรุงรักษาระบบข้อมูล (System acquisition, development and maintenance)	๒๔
๘.๑ ข้อกำหนดด้านความปลอดภัยของระบบ (Security requirements of information system)	๒๔
๘.๒ ความมั่นคงปลอดภัยสำหรับกระบวนการพัฒนาและสนับสนุน (Security in development and support processes)	๒๕

๘.๓ ข้อมูลสำหรับการทดสอบ (Test data)	๒๖
๙. ความสัมพันธ์กับผู้ให้บริการภายนอก (Supplier relationships)	๒๖
๙.๑ ความมั่นคงปลอดภัยสารสนเทศกับความสัมพันธ์กับผู้ให้บริการภายนอก (Information security in supplier relationship)	๒๖
๙.๒ การบริหารจัดการการให้บริการโดยผู้ให้บริการภายนอก	๒๗
๑๐. การบริหารจัดการเหตุการณ์ด้านความมั่นคงปลอดภัยสารสนเทศ (Information security incident management)	๒๘
๑๐.๑ การบริหารจัดการเหตุการณ์ด้านความมั่นคงปลอดภัยสารสนเทศและการปรับปรุง (Management of information security incidents and improvements)	๒๘
๑๑. มุมมองด้านความมั่นคงปลอดภัยสารสนเทศของการบริหารความต่อเนื่องของธุรกิจ (Information security aspects of business continuity management)	๒๙
๑๑.๑ ความต่อเนื่องด้านความมั่นคงปลอดภัยสารสนเทศ (Information security continuity)	๒๙
๑๑.๒ การเตรียมการอุปกรณ์ประมวผลสำรอง (Redundancies)	๓๐
๑๒. ความสอดคล้อง (Compliance)	๓๑
๑๒.๑ ความสอดคล้องกับความต้องการด้านกฎหมายและในสัญญาจ้าง (Compliance with legal and contractual requirements)	๓๑
๑๒.๒ การทบทวนความมั่นคงปลอดภัยสารสนเทศ (Information security reviews)	๓๒
๑๓. การบริหารจัดการความเสี่ยง (Risk management)	๓๒
๑๓.๑ แนวปฏิบัติในการตรวจสอบและประเมินความเสี่ยง (Information security risk assessment)	๓๒
๑๓.๒ การตรวจสอบและประเมินความเสี่ยง	๓๓
๑๓.๓ ดำเนินการตรวจสอบและประเมินความเสี่ยงที่อาจเกิดขึ้นกับระบบสารสนเทศของหน่วยงาน	๓๓
๑๓.๔ เครื่องหรือโปรแกรมคอมพิวเตอร์ซึ่งทำงานให้บริการในระบบเครือข่ายแก่ลูกค้า (ซึ่งให้บริการผู้ใช้อีกหนึ่ง)	๓๓

ขอบเขตของเอกสาร

แนวนโยบายและแนวปฏิบัติในการรักษาความมั่นคงปลอดภัยด้านสารสนเทศ แบ่งออกเป็นทั้งสิ้น ๑๓ ส่วน ดังนี้

- ส่วนที่ ๑ นโยบายความมั่นคงปลอดภัยสารสนเทศ (Information Security Policy)
- ส่วนที่ ๒ โครงสร้างความมั่นคงปลอดภัยสารสนเทศ (Organization of Information Security)
- ส่วนที่ ๓ ความมั่นคงปลอดภัยสำหรับทรัพยากรบุคคล (Human Resource Security)
- ส่วนที่ ๔ การบริหารจัดการทรัพย์สิน (Asset Management)
- ส่วนที่ ๕ ความมั่นคงปลอดภัยทางกายภาพและสภาพแวดล้อม (Physical and environmental security)
- ส่วนที่ ๖ ความมั่นคงปลอดภัยสำหรับการดำเนินงาน (Operations security)
- ส่วนที่ ๗ ความมั่นคงปลอดภัยสำหรับการสื่อสารข้อมูล (Communications security)
- ส่วนที่ ๘ การจัดการ การพัฒนา และการบำรุงรักษาระบบข้อมูล (System acquisition, development and maintenance)
- ส่วนที่ ๙ ความสัมพันธ์กับผู้ให้บริการภายนอก (Supplier relationships)
- ส่วนที่ ๑๐ การบริหารจัดการเหตุการณ์ด้านความมั่นคงปลอดภัยสารสนเทศ (Information security incident management)
- ส่วนที่ ๑๑ มุมมองด้านความมั่นคงปลอดภัยสารสนเทศของการบริหารความต่อเนื่องของธุรกิจ (Information security aspects of business continuity management)
- ส่วนที่ ๑๒ ความสอดคล้อง (Compliance)
- ส่วนที่ ๑๓ การบริหารจัดการความเสี่ยง (Risk management)

คำนิยาม

คำที่	คำนิยาม	ความหมาย
๑.	เครื่องคอมพิวเตอร์ (Computer)	เครื่องคอมพิวเตอร์แบบตั้งโต๊ะและเครื่องคอมพิวเตอร์แบบพกพา
๒.	เครื่องบริการ (Server)	เครื่องแม่ข่ายหรือโปรแกรมคอมพิวเตอร์ ซึ่งทำงานให้บริการ ในระบบเครือข่ายแก่ลูกข่าย (ซึ่งให้บริการผู้ใช้อีกหนึ่ง) เครื่องคอมพิวเตอร์ที่ทำหน้าที่เป็นเครื่องบริการนี้ควรมีประสิทธิภาพสูง (ซึ่งให้บริการผู้ใช้) มีความเสถียร สามารถให้บริการแก่ผู้ใช้ได้เป็นจำนวนมาก
๓.	เจ้าของ (Owner)	เจ้าของทรัพย์สินหรือระบบ โดยอาจเป็นบุคคล แผนก หรือหน่วยงาน
๔.	เวลาอ้างอิงสากล (Stratum ๐)	การเปรียบเทียบเวลาของเครื่องคอมพิวเตอร์แม่ข่ายที่ใช้ในการเก็บข้อมูลจราจรทางคอมพิวเตอร์ (Log) กับเวลามาตรฐานสากล ในประเทศไทยนั้น เราอ้างอิงกับหน่วยงานมาตรฐาน (เช่น กรมอุตุนิยมวิทยา กองทัพเรือ ศูนย์เทคโนโลยีอิเล็กทรอนิกส์และคอมพิวเตอร์แห่งชาติ) เพื่อให้สอดคล้องกับพระราชบัญญัติว่าการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. ๒๕๕๐
๕.	เหตุการณ์ด้านความมั่นคงปลอดภัย (Information security event)	กรณีที่เกิดเหตุการณ์สภาพของบริการหรือระบบเครือข่ายที่แสดงให้เห็นความเป็นไปได้ ที่จะเกิดการฝ่าฝืนนโยบายด้านความมั่นคงปลอดภัยหรือมาตรการป้องกันที่ล้มเหลว หรือเหตุการณ์อื่นไม่อาจรู้ได้ว่า อาจเกี่ยวข้องกับความปลอดภัย
๖.	แบนด์วิดท์ (Bandwidth)	ปริมาณข้อมูลที่ไหลเข้าหรือออกจากจุดใดจุดหนึ่งของระบบ เป็นการแสดงให้เห็นถึงปริมาณข้อมูลที่สามารถถ่ายโอนได้ในช่วงเวลาหนึ่ง และเป็นการบอกถึงความเร็วในการรับส่งข้อมูล
๗.	ไฟร์วอลล์ (Firewall)	เทคโนโลยีป้องกันการบุกรุกจากบุคคลภายนอก เพื่อไม่ให้ผู้ที่ไม่ได้รับอนุญาตเข้ามาใช้ข้อมูลและทรัพยากรในเครือข่าย โดยอาจใช้ทั้งฮาร์ดแวร์ และซอฟต์แวร์ในการรักษาความปลอดภัย
๘.	การเข้าถึงหรือควบคุมการใช้งานสารสนเทศ	การอนุญาต การกำหนดสิทธิ หรือ การมอบอำนาจให้ใช้งาน เข้าถึงหรือใช้งานระบบเครือข่ายหรือระบบสารสนเทศ ทั้งทางอิเล็กทรอนิกส์และทางกายภาพ รวมทั้งการอนุญาตเช่นนั้นสำหรับบุคคลภายนอก ตลอดจนกำหนดข้อปฏิบัติเกี่ยวกับการเข้าถึงโดยมิชอบเอาไว้ด้วยก็ได้
๙.	การเข้ารหัสลับ (Encryption/ Cryptography)	การนำข้อมูลมาเข้ารหัสลับเพื่อป้องกันการลักลอบเข้ามาใช้ข้อมูล ผู้ที่สามารถเปิดไฟล์ข้อมูลที่เข้ารหัสลับไว้จะต้องมีโปรแกรมถอดรหัสเพื่อให้ข้อมูลกลับมาใช้งานได้ตามปกติ
๑๐.	ข้อมูลคอมพิวเตอร์	ข้อมูล ข้อความ คำสั่ง ชุดคำสั่ง หรือสิ่งอื่นใด บรรดาที่อยู่ในระบบคอมพิวเตอร์ในสภาพที่ระบบคอมพิวเตอร์อาจประมวลผลได้ และให้

	หมายความว่ารวมถึงข้อมูลอิเล็กทรอนิกส์ตามกฎหมายว่าด้วยธุรกรรมทางอิเล็กทรอนิกส์
๑๑. ข้อมูลจราจรทางคอมพิวเตอร์ (Log)	ข้อมูลที่เกี่ยวข้องกับการติดต่อสื่อสารของระบบคอมพิวเตอร์ ซึ่งแสดงถึงแหล่งกำเนิด ต้นทาง ปลายทาง เส้นทาง วันที่ ปริมาณ ระยะเวลา และชนิดของบริการอื่นๆ ที่เกี่ยวข้องในการติดต่อสื่อสารของระบบคอมพิวเตอร์นั้น
๑๒. ความมั่นคงปลอดภัยด้านสารสนเทศ (Information security)	การดำรงไว้ซึ่งความลับ (Confidentiality) ความถูกต้องครบถ้วน (Integrity) และสภาพพร้อมใช้งาน (Availability) ของสารสนเทศ รวมทั้งคุณสมบัติอื่น ได้แก่ ความถูกต้องแท้จริง (Authenticity) ความรับผิดชอบ (Accountability) การห้ามปฏิเสธความรับผิดชอบ (Non-Repudiation) และ ความน่าเชื่อถือ (Reliability)
๑๓. ช่องโหว่หรือจุดอ่อน (Vulnerability)	ช่องโหว่หรือจุดอ่อนหรือความอ่อนแอในโปรแกรมคอมพิวเตอร์ ซึ่งยอมให้เกิดการกระทำที่ไม่ได้รับอนุญาตได้ โดยเกิดจากข้อบกพร่องจากการออกแบบโปรแกรม ทำให้มีการอาศัยข้อบกพร่องดังกล่าวเพื่อเข้าถึงข้อมูลโดยไม่ได้รับอนุญาต
๑๔. ค่าโดยปริยาย (Default)	ค่าที่เครื่องคอมพิวเตอร์หรือโปรแกรมได้กำหนดไว้ล่วงหน้า และนำไปใช้ได้โดยปริยาย หากไม่มีการเปลี่ยนแปลงจากผู้ใช้งาน
๑๕. จดหมายอิเล็กทรอนิกส์ (E-mail)	ระบบที่บุคคลใช้ในการรับส่งข้อความระหว่างกันโดยผ่านเครื่องคอมพิวเตอร์และระบบเครือข่ายที่เชื่อมโยงถึงกัน ข้อมูลที่ส่งจะเป็นได้ทั้งตัวอักษร ภาพถ่าย ภาพกราฟิก ภาพเคลื่อนไหว และเสียง ที่ผู้ส่งสามารถส่งข่าวสารไปยังผู้รับคนเดียวหรือหลายคนก็ได้ มาตรฐานที่ใช้ในการรับส่งข้อมูลชนิดนี้ได้แก่ SMTP, POP๓ และ IMAP เป็นต้น
๑๖. ชื่อเครื่องคอมพิวเตอร์ (Computer name)	ชื่อที่กำหนดเฉพาะให้กับเครื่องคอมพิวเตอร์บนระบบเครือข่าย โดยจะมีชื่อที่ไม่ซ้ำกัน ทำให้บ่งบอกได้ว่าเป็นเครื่องคอมพิวเตอร์ใดในระบบเครือข่าย
๑๗. ชื่อโดเมนย่อย (Sub domain name)	ส่วนย่อยที่จะช่วยขยายให้ทราบถึงกลุ่มต่าง ๆ ภายในโดเมนนั้น ซึ่งเป็นชื่อที่ระบุให้กับผู้ใช้เพื่อเข้ามาয়เว็บไซต์ของตน หรืออาจจะใช้ "ที่อยู่เว็บไซต์" แทนก็ได้
๑๘. ชื่อผู้ใช้ (Username)	ชุดของตัวอักษรหรือตัวเลขที่ถูกกำหนดขึ้นเพื่อใช้ในการลงบันทึกเข้า (Login) เพื่อใช้งานเครื่องคอมพิวเตอร์และระบบเครือข่ายที่มีการกำหนดสิทธิการใช้งานไว้
๑๙. ซอฟต์แวร์ (Software)	ชุดคำสั่งหรือโปรแกรมที่ใช้สั่งงานให้คอมพิวเตอร์ทำงาน
๒๐. บัญชีผู้ใช้ (Account)	รายชื่อผู้มีสิทธิใช้งานเครื่องคอมพิวเตอร์ และบริการในระบบเครือข่ายของหน่วยงาน
๒๑. ปรับให้เป็นปัจจุบัน (Update)	การปรับปรุงข้อมูลด้านต่างๆ ของสารสนเทศให้ทันสมัยอยู่เสมอ

๒๒. ผู้ใช้งาน /ผู้ใช้งานทั่วไป (User/General user)	ข้าราชการ เจ้าหน้าที่ พนักงานของรัฐ ลูกจ้าง ผู้ดูแลระบบ ผู้บริหาร องค์กร ผู้รับบริการ ผู้ใช้งานทั่วไป
๒๓. ผู้ดูแลระบบ (System administrator)	ผู้ที่ได้รับมอบหมายจากผู้บังคับบัญชาให้มีหน้าที่รับผิดชอบดูแลรักษาหรือ จัดการระบบคอมพิวเตอร์และระบบเครือข่ายไม่ว่าส่วนหนึ่งส่วนใด
๒๔. ผู้ตรวจสอบระบบ สารสนเทศของหน่วยงาน (Internal IT auditor)	ผู้ที่ได้รับมอบหมายจากผู้บังคับบัญชา ให้มีหน้าที่ตรวจสอบข้อมูลจราจร ทางคอมพิวเตอร์ (Log) และรับผิดชอบให้สามารถเข้าถึงข้อมูลจราจร ทางคอมพิวเตอร์ (Log)
๒๕. ผู้ตรวจสอบระบบ สารสนเทศจากหน่วยงาน ภายนอก (External IT auditor)	ผู้ที่ได้รับมอบหมายจากหน่วยงานให้มีสิทธิในการตรวจสอบระบบ สารสนเทศหรือระบบเครือข่ายของหน่วยงาน
๒๖. ผู้บังคับบัญชา/ผู้บริหาร (Management)	ผู้มีอำนาจสั่งการตามโครงสร้างการบริหารของกรมการท่องเที่ยว
๒๗. ผู้รับฝากทรัพย์สิน (Custodian)	ผู้ที่มีหน้าที่ดูแลรักษาทรัพย์สินหรือระบบ โดยอาจเป็นบุคคล แผนก หรือ หน่วยงาน
๒๘. รหัสผ่าน (Password)	ตัวอักษรหรืออักขระหรือตัวเลข ที่ใช้เป็นเครื่องมือในการตรวจสอบยืนยัน ตัวบุคคล เพื่อควบคุมการเข้าถึงข้อมูลและระบบข้อมูลในการรักษา ความมั่นคงปลอดภัยของข้อมูลและระบบเทคโนโลยีสารสนเทศ
๒๙. ระบบเครือข่าย (Network)	ระบบที่สามารถใช้ในการติดต่อสื่อสารหรือการส่งข้อมูลและสารสนเทศ ระหว่างระบบเทคโนโลยีสารสนเทศต่าง ๆ ของหน่วยงานได้ เช่น ระบบแลน (LAN) ระบบอินทราเน็ต (Intranet) ระบบอินเทอร์เน็ต (Internet) เป็นต้น
๓๐. ระบบคอมพิวเตอร์ (Computer system)	อุปกรณ์หรือชุดอุปกรณ์ของคอมพิวเตอร์ที่เชื่อมการทำงานเข้าด้วยกัน โดยได้มีการกำหนดคำสั่ง ชุดคำสั่ง หรือสิ่งอื่นใด และแนวทางปฏิบัติงาน ให้อุปกรณ์ หรือชุดอุปกรณ์ทำหน้าที่ประมวลผลข้อมูลโดยอัตโนมัติ
๓๑. ระบบจดหมาย อิเล็กทรอนิกส์ของ กรมการท่องเที่ยว	การส่งข้อความหรือข่าวสารเพื่อการปฏิบัติงานในภาครัฐจากบุคคลหนึ่ง ไปยังอีกบุคคลหนึ่ง ผ่านคอมพิวเตอร์และระบบเครือข่าย ซึ่งอยู่ในรูปแบบ ของสัญญาณข้อมูลที่เป็นอิเล็กทรอนิกส์ เข้ามาสู่ Mailbox ที่ถูกจัดเก็บ ในเครื่องแม่ข่ายของผู้รับปลายทาง ซึ่งเป็นจดหมายอิเล็กทรอนิกส์ที่ กรมการท่องเที่ยวดำเนินการเอง
๓๒. ระบบสารสนเทศ (Information system)	ระบบงานของหน่วยงานที่นำเอาเทคโนโลยีสารสนเทศ ระบบคอมพิวเตอร์ และระบบเครือข่ายมาช่วยในการสร้างสารสนเทศที่หน่วยงานสามารถ นำมาใช้ประโยชน์ในการวางแผน การบริหาร การสนับสนุนการให้บริการ การพัฒนาและควบคุมการติดต่อสื่อสาร ซึ่งมีองค์ประกอบ เช่น ระบบ คอมพิวเตอร์ ระบบเครือข่าย โปรแกรม ข้อมูลและสารสนเทศ เป็นต้น

๓๓. ระบบอินเทอร์เน็ต (Internet)	ระบบเครือข่ายอิเล็กทรอนิกส์ที่เชื่อมต่อระบบเครือข่ายคอมพิวเตอร์ต่างๆ ของหน่วยงานเข้ากับเครือข่ายอินเทอร์เน็ตสากล
๓๔. ระบบอินทราเน็ต (Intranet)	ระบบเครือข่ายอิเล็กทรอนิกส์ที่เชื่อมต่อระบบคอมพิวเตอร์ต่างๆ ภายในหน่วยงานเข้าด้วยกัน เป็นระบบเครือข่ายที่มีจุดประสงค์เพื่อการติดต่อสื่อสารแลกเปลี่ยนข้อมูลและสารสนเทศภายในหน่วยงาน
๓๕. ลงบันทึกเข้า (Login)	กระบวนการที่ผู้ใช้งานต้องทำให้เสร็จสิ้นตามเงื่อนไขที่ตั้งไว้เพื่อใช้งานระบบคอมพิวเตอร์และระบบเครือข่าย ซึ่งปกติแล้วจะอยู่ในรูปแบบของการกรอกชื่อผู้ใช้ (Username) และรหัสผ่าน (Password) ให้ถูกต้อง
๓๖. ลงบันทึกออก (Logout)	กระบวนการที่ผู้ใช้งานทำเพื่อสิ้นสุดการใช้งานระบบคอมพิวเตอร์และระบบเครือข่าย
๓๗. สถานการณ์ด้านความมั่นคงปลอดภัยที่ไม่พึงประสงค์หรือไม่อาจคาดคิด (Information security incident)	สถานการณ์ด้านความมั่นคงปลอดภัยที่ไม่พึงประสงค์หรือไม่อาจคาดคิด (unwanted or unexpected) ซึ่งอาจทำให้ระบบของหน่วยงานถูกบุกรุกหรือโจมตี และความมั่นคงปลอดภัยถูกคุกคาม
๓๘. สารสนเทศ (Information)	ข้อเท็จจริงที่ได้จากการนำข้อมูลมาผ่านการประมวลผล การจัดระเบียบให้ข้อมูลซึ่งอาจอยู่ในรูปของตัวเลข ข้อความ หรือภาพกราฟิก ให้เป็นระบบที่ผู้ใช้สามารถเข้าใจได้ง่าย และสามารถนำไปใช้ประโยชน์ในการบริหาร การวางแผน การตัดสินใจ และอื่นๆ
๓๙. สิทธิของผู้ใช้งาน	สิทธิทั่วไป สิทธิจำเพาะ สิทธิพิเศษ และสิทธิอื่นใดที่เกี่ยวข้องกับระบบเทคโนโลยีสารสนเทศและการสื่อสารของหน่วยงาน
๔๐. สินทรัพย์ (Asset)	ข้อมูล ระบบข้อมูล และทรัพย์สินด้านเทคโนโลยีสารสนเทศและการสื่อสารของหน่วยงาน ได้แก่ เครื่องคอมพิวเตอร์ อุปกรณ์ระบบเครือข่าย ซอฟต์แวร์ที่มีลิขสิทธิ์ เป็นต้น
๔๑. สื่อบันทึกพกพา (Portable storage media)	สื่ออิเล็กทรอนิกส์ที่ใช้ในการบันทึกหรือจัดเก็บข้อมูล ได้แก่ Flash Drive หรือ Handy Drive หรือ Thumb Drive หรือ External Hard disk หรือ Floppy disk เป็นต้น
๔๒. หน่วยงาน	ทุกหน่วยงานภายใต้กรมการท่องเที่ยว
๔๓. หน่วยงานด้านสารสนเทศ	หน่วยงานภายใต้กรมการท่องเที่ยวที่รับผิดชอบดูแลระบบสารสนเทศและระบบเครือข่าย
๔๔. หน่วยงานภายนอก	องค์กร หรือหน่วยงานภายนอกที่ได้รับอนุญาตให้มีสิทธิในการเข้าถึงและใช้งานข้อมูลหรือทรัพย์สินต่างๆ ของหน่วยงาน โดยจะได้รับสิทธิในการใช้ระบบตามอำนาจหน้าที่และต้องรับผิดชอบในการรักษาความลับของข้อมูล
๔๕. ผู้บริหารระดับสูงสุด (Chief Information Officer: CEO)	อธิบดีกรมการท่องเที่ยว

นโยบายและแนวปฏิบัติในการรักษาความมั่นคงปลอดภัยสารสนเทศ (Information Security Policy and Procedure)

1. นโยบายความมั่นคงปลอดภัยสารสนเทศ (Information Security Policies)

นโยบายความมั่นคงปลอดภัยด้านสารสนเทศมีวัตถุประสงค์ เพื่อกำหนดทิศทางการบริหารจัดการและให้การสนับสนุนทางความมั่นคงปลอดภัยด้านสารสนเทศ โดยมีความสอดคล้องในการดำเนินงานขององค์กร กฎหมาย ประกาศ ระเบียบ คำสั่งหรือแนวปฏิบัติอื่นใดที่เกี่ยวข้อง

โดยผู้บริหารระดับสูงต้องจัดให้มีการปรับปรุงและทบทวนนโยบายและแนวปฏิบัติในการรักษาความมั่นคงปลอดภัยของข้อมูล (Review of the policies for information security) เพื่อให้การรักษาความมั่นคงปลอดภัยสารสนเทศคงความถูกต้อง สมบูรณ์ และความพร้อมใช้งาน โดยสอดคล้องเหมาะสมกับการเปลี่ยนแปลงและความต้องการทางธุรกิจขององค์กรให้เป็นปัจจุบัน อย่างน้อยปีละ ๑ ครั้ง

2. โครงสร้างความมั่นคงปลอดภัยสารสนเทศ (Organization of Information Security)

2.1 โครงสร้างภายในองค์กร (Internal organization)

เพื่อให้มีการกำหนดกรอบการบริหารจัดการโดยต้องมีการเริ่มต้นและควบคุมการปฏิบัติ และการดำเนินการด้านความมั่นคงปลอดภัยสารสนเทศภายในองค์กร

2.1.1 บทบาทและหน้าที่ความรับผิดชอบด้านความมั่นคงปลอดภัยสารสนเทศ

บทบาทและความรับผิดชอบของคณะกรรมการบริหารด้านความมั่นคงปลอดภัยสารสนเทศ คณะทำงานด้านความมั่นคงปลอดภัยสารสนเทศ หน่วยงานทางธุรกิจ และบุคคลต่างๆ ได้รับการกำหนดไว้ในนโยบายระบบบริหารจัดการด้านความมั่นคงปลอดภัยสารสนเทศ (ISMS Policy)

2.1.2 การแบ่งแยกหน้าที่ความรับผิดชอบ

- ก) ผู้มีหน้าที่ในการบริหารจัดการระบบและเครือข่ายจะต้องแยกออกจากกัน
- ข) ไม่ควรให้บุคคลเดียวกันทำงานที่สำคัญๆ ในกระบวนการเดียวกัน เพื่อป้องกันการทุจริต และการให้สิทธิมากเกินไป

2.1.3 การติดต่อกับหน่วยงานผู้มีอำนาจ

คณะกรรมการบริหารด้านความมั่นคงปลอดภัยจะต้องทำการสื่อสารอย่างมีประสิทธิภาพกับหน่วยงานที่มีอำนาจในการบังคับใช้กฎหมาย หน่วยงานด้านกฎระเบียบ ผู้ให้บริการทางด้านข้อมูล และผู้ให้บริการทางด้านการโทรคมนาคม

2.1.4 การติดต่อกับผู้ที่อยู่ในแวดวงด้านการรักษาความปลอดภัยและผู้เชี่ยวชาญด้านความปลอดภัย

- ก) องค์กรจะต้องสมัครเป็นสมาชิกการแจ้งเตือนข่าวสารด้านความปลอดภัยจากผู้ค้า เพื่อช่วยเป็นข้อมูลในการบริหารจัดการช่องโหว่
- ข) องค์กรควรเก็บรักษารายการข้อมูลติดต่อกับผู้ให้บริการและผู้เชี่ยวชาญด้านความปลอดภัยสารสนเทศ เพื่อให้สามารถขอความช่วยเหลือและรับทราบข่าวสารความเคลื่อนไหว รวมทั้งข้อมูล แนวทางในการปฏิบัติทางด้านความปลอดภัยที่ได้รับความนิยม

2.1.5 ความมั่นคงปลอดภัยสำหรับสารสนเทศในการบริหารโครงการ

- ก) ต้องมีการระบุถึงความมั่นคงปลอดภัยสารสนเทศในวัตถุประสงค์ของโครงการสำหรับทุกโครงการที่เกี่ยวข้องทั้งหมด
- ข) โครงการทั้งหมดต้องครอบคลุมถึงความมั่นคงปลอดภัยสารสนเทศ

2.2 อุปกรณ์คอมพิวเตอร์แบบพกพาและการปฏิบัติงานจากระยะไกล (Mobile devices and teleworking)

การรักษาความมั่นคงปลอดภัยของอุปกรณ์คอมพิวเตอร์แบบพกพา และการปฏิบัติงานจากระยะไกล มีขอบเขตครอบคลุมถึงอุปกรณ์พกพา ดังนี้

2.2.1 อุปกรณ์แบบพกพา หรือเคลื่อนที่ใดๆ ที่ใช้ในการเก็บข้อมูลหรือประมวลผลข้อมูลขององค์กร

- ก) อุปกรณ์แบบพกพา หรือเคลื่อนที่ใดๆ ที่ต้องการเชื่อมต่อเข้าสู่ระบบเครือข่ายภายในของกรมการท่องเที่ยวจากระยะไกลต้องได้รับอนุญาตตามแบบฟอร์มขอเข้าใช้งานระบบสารสนเทศ
- ข) การจัดการข้อมูล ต้องเป็นไปตามมาตรฐานการจัดการข้อมูลตามระดับชั้นสูงสุดที่มีที่อยู่ภายในอุปกรณ์นั้น

2.2.2 การป้องกันทางกายภาพของอุปกรณ์คอมพิวเตอร์แบบพกพา

- ก) อุปกรณ์ใด ๆ ที่ต้องนำไปใช้ในกิจกรรมของหน่วยงานภายนอกสถานที่ ต้องมีการควบคุมด้านความมั่นคงปลอดภัยในระดับเดียวกับอุปกรณ์ที่ใช้ภายในสำนักงาน
- ข) ต้องมีการป้องกันหรือการล็อคอุปกรณ์พกพา และคอมพิวเตอร์พกพาอย่างเหมาะสมเมื่อไม่ได้ใช้งานภายในสำนักงาน
- ค) บุคลากรต้องไม่วางอุปกรณ์ไว้ในที่สาธารณะโดยที่ไม่มีคนดูแล บุคลากรมีหน้าที่รับผิดชอบในการดูแลและป้องกันอุปกรณ์ต่างๆ ที่ได้รับ
- ง) อุปกรณ์พกพาของกรมการท่องเที่ยวที่จะนำไปใช้ภายนอกสำนักงานต้องมีการเข้ารหัสลับของฮาร์ดดิส (Hard Disk encryption) เพื่อป้องกันข้อมูลรั่วไหลกรณีเครื่องสูญหาย และมีการเข้าถึงฮาร์ดดิสจากอุปกรณ์พกพา
- จ) ต้องปฏิบัติตามคู่มือป้องกันอุปกรณ์ที่ได้รับจากผู้ผลิตตลอดเวลา เช่น การป้องกันจากการเข้าใกล้สนามแม่เหล็กไฟฟ้า

2.2.3 การป้องกันข้อมูลและการเข้าถึงของอุปกรณ์คอมพิวเตอร์แบบพกพา

- ก) อุปกรณ์พกพาต้องได้รับการป้องกันจากการเข้าถึงโดยไม่ได้รับอนุญาต
- ข) มีการบังคับใช้มาตรการการเข้าถึงในระดับไบออส (BIOS) สำหรับคอมพิวเตอร์พกพา
- ค) ไม่ทำการปรับแต่งไบออส (BIOS) หรือการตั้งค่าระบบ (Configuration) อื่นใดที่อาจส่งผลกระทบต่อระบบการทำงานของคอมพิวเตอร์ อันเป็นเหตุให้ไม่สามารถเปิดเครื่องใช้งานได้ปกติ
- ง) ต้องติดตั้งซอฟต์แวร์ป้องกันคอมพิวเตอร์ไวรัส (Antivirus) บนอุปกรณ์พกพา และทำการปรับปรุงข้อมูลไวรัส (Virus Pattern) ให้ทันสมัยอยู่เสมอ

- จ) ต้องทำการสำรองข้อมูลสารสนเทศที่อยู่ในอุปกรณ์พกพาบนเครื่องคอมพิวเตอร์แม่ข่าย หรือหากจำเป็นสามารถสำรองข้อมูลสารสนเทศบนสื่อบันทึกพกพา
- ฉ) ข้อมูลสารสนเทศสำรองบนสื่อบันทึกพกพาต้องได้รับการป้องกันตามมาตรฐานการจัดประเภทข้อมูล การจัดทำป้ายและการจัดการกับข้อมูล
- ช) ข้อมูลสารสนเทศสำรองบนสื่อบันทึกพกพาต้องถูกลบ หรือทำลายอย่างปลอดภัยตาม มาตรฐานการกำจัดสื่อเมื่อไม่ได้ใช้งาน

3. ความมั่นคงปลอดภัยสำหรับทรัพยากรบุคคล(Human Resource Security)

3.1 ก่อนการจ้างงาน (Prior to employment)

3.1.1 การคัดเลือก

อ้างอิงตามนโยบายด้านทรัพยากรบุคคลของกรมการท่องเที่ยว

3.2 ระหว่างการจ้างงาน (During employment)

3.2.1 หน้าที่ความรับผิดชอบของผู้บริหาร

คณะกรรมการบริหารด้านความมั่นคงปลอดภัยสารสนเทศจะถูกแต่งตั้งขึ้นเพื่อดูแลการบริการ ความปลอดภัยภายในองค์กรและฝ่ายบริหารจะต้องให้การสนับสนุนให้เกิดความปลอดภัยทางข้อมูลภายใน องค์กรผ่านทางทิศทางในการดำเนินการ การแสดงให้เห็นเป็นตัวอย่าง การมอบหมายงานอย่างชัดเจน และการ รับทราบหน้าที่รับผิดชอบทางด้านความมั่นคงปลอดภัยของข้อมูล

3.2.2 การสร้างความตระหนักรู้ การให้ความรู้และการฝึกอบรมด้านความมั่นคงปลอดภัยสารสนเทศ (Information security awareness, education and training)

ต้องสร้างความตระหนักรู้ และให้ความรู้ด้านความมั่นคงปลอดภัยสารสนเทศให้กับบุคลากร ใหม่และผู้รับจ้างหรือหน่วยงานภายนอกก่อนเข้าทำงาน รวมถึงจัดให้กับบุคลากรปัจจุบันอย่างน้อยปีละ ๑ ครั้ง โดยมีการทดสอบเพื่อวัดผลความสำเร็จในการฝึกอบรมดังกล่าว

3.2.3 กระบวนการทางวินัย

อ้างอิงตามข้อบังคับ ขององค์กร ว่าด้วยเรื่องวินัยและการลงโทษพนักงาน

3.3 การสิ้นสุดหรือการเปลี่ยนแปลงการจ้างงาน (Termination and change of employment)

3.3.1 หน้าที่ความรับผิดชอบ

- ก) มีการกำหนดถึงบทบาทและหน้าที่ความรับผิดชอบที่ยังต้องคงไว้ภายหลังจากสิ้นสุดหรือ เปลี่ยนแปลงการจ้างและแจ้งให้กับพนักงาน หรือหน่วยงานภายนอกได้รับทราบและ ปฏิบัติตาม
- ข) มีการส่งถ่ายความรู้ในการทำงานอย่างเป็นทางการและมีประสิทธิภาพให้กับบุคคลที่ได้รับ มอบหมายก่อนสิ้นสุดหรือเปลี่ยนแปลงสัญญาจ้างงาน

4. การบริหารจัดการสินทรัพย์ (Asset Management)

4.1 หน้าที่ความรับผิดชอบต่อสินทรัพย์ (Responsibility for assets)

ผู้บริหารต้องกำกับให้มีการจัดทำรายการสินทรัพย์ โดยกำหนดผู้ที่เป็นเจ้าของและหน้าที่ความรับผิดชอบที่มีต่อสินทรัพย์นั้น

4.1.1 บัญชีรายการสินทรัพย์

- ก) สินทรัพย์ทั้งหมดที่เกี่ยวข้องกับการดำเนินงานจะต้องได้รับการจัดเก็บในรายการทรัพย์สิน โดยครอบคลุมถึงทรัพย์สินประเภทต่าง ๆ ดังนี้
 - ๑) ข้อมูล
 - ๒) อุปกรณ์ประมวลผลสารสนเทศ เช่น เครื่องคอมพิวเตอร์ เครื่องแม่ข่าย และอุปกรณ์คอมพิวเตอร์
 - ๓) ระบบเครือข่าย และอุปกรณ์เครือข่าย
 - ๔) ซอฟต์แวร์ และโปรแกรมที่ใช้สนับสนุนการปฏิบัติงาน
- ข) รายการทรัพย์สินต้องทำการทบทวนบัญชีรายการทรัพย์สินเป็นประจำ อย่างน้อยปีละ ๑ ครั้ง
- ค) ต้องทำการติดป้ายระบุทรัพย์สินทางกายภาพ (Physical asset)
- ง) การตั้งชื่อทรัพย์สินทางกายภาพ (Physical asset) ให้กำหนดเป็นรูปแบบเดียวกัน โดยให้สอดคล้องตามระเบียบครุภัณฑ์ของกรมการท่องเที่ยว
- จ) บันทึกตำแหน่งที่ตั้งของทรัพย์สินลงในรายการทรัพย์สิน

4.1.2 ผู้ถือครองทรัพย์สิน

ทรัพย์สินทั้งหมดจะต้องมีผู้ดูแลและต้องมีการกำหนดชื่อผู้เป็นเจ้าของ เจ้าของทรัพย์สินอาจจะเป็นบุคคลหรือแผนกก็ได้ ในกรณีที่กำหนดให้ทรัพย์สินใดเป็นของแผนก ความรับผิดชอบต่อทรัพย์สินดังกล่าวจะขึ้นกับหัวหน้าแผนก

4.1.3 การใช้ทรัพย์สินอย่างเหมาะสม

- ก) การใช้งานทั่วไป
 - ๑) การใช้งานทรัพย์สินจะทำได้เฉพาะพนักงานหรือผู้ที่ได้รับอนุญาตเท่านั้น
 - ๒) การใช้งานจะต้องไม่เป็นการขัดขวางประสิทธิภาพในการปฏิบัติงานภายในองค์กร เช่น ไม่อนุญาตให้ส่งอีเมลล์ลูกโซ่ ฯลฯ
 - ๓) ไม่อนุญาตให้รับหรือส่งไฟล์ที่เป็นการละเมิดกฎหมาย หรือนโยบายขององค์กร
 - ๔) ข้อมูล ข้อความ และเอกสารใดๆ ที่จัดเก็บไว้ในระบบสารสนเทศขององค์กรให้ถือเป็นทรัพย์สินขององค์กร
- ข) โทรศัพท์และข้อความเสียง (Telephone and Voice Mail)
 - ๑) ไม่ควรมีการสื่อสารข้อมูลที่มีระดับชั้นความลับในพื้นที่ที่ไม่มีการควบคุม หรือมีบุคคลที่ไม่มีส่วนเกี่ยวข้องอยู่ในสถานที่นั้นด้วย
 - ๒) ควรมีการกำหนดรหัสผ่านเพื่อใช้เปิดข้อความเสียง ยกเว้นมีข้อจำกัดทางเทคนิค

- ๓) ไม่ควรระบุรายละเอียดของเจ้าของกล่องข้อความตอบรับมากเกินไป เพื่อป้องกันการนำข้อมูลไปใช้ในการหลอกลวงทางสังคม (Social Engineering)
- ค) โทรสาร (Facsimile/ Fax)
 - ๑) ไม่ควรวางเครื่องโทรสารในพื้นที่ส่วนกลาง หรือพื้นที่ที่ไม่มีการควบคุมการเข้าถึง เช่น ไม่วางเครื่องโทรสารที่ทางเดินระหว่างห้อง
 - ๒) ควรมีการระบุชื่อผู้รับ จำนวนหน้า ของเอกสารที่จัดส่งในหน้าแรก
 - ๓) ควรมีการตรวจสอบหมายเลขที่ต้องการจัดส่งก่อนทุกครั้ง
 - ๔) หากพบว่ามียอดผิดพลาด เช่น ส่งไม่ผ่าน ให้ตรวจสอบหมายเลขโทรสารกับผู้รับก่อนจัดส่งใหม่
 - ๕) ควรหลีกเลี่ยงการจัดส่งข้อมูลส่วนบุคคลทางโทรสาร ยกเว้นมีเหตุจำเป็น เช่น ใบสมัครของลูกค้า เป็นต้น
 - ๖) หากมีความจำเป็นต้องส่งข้อมูลที่มีชั้นความลับตั้งแต่ระดับลับ (Confidential) ขึ้นไป กำหนดให้มีการสื่อสารไปยังผู้รับให้ทราบก่อนจัดส่ง ทั้งนี้ควรแจ้งให้ผู้รับรอรับเอกสารหน้าเครื่องโทรสาร
 - ๗) กำหนดแนวปฏิบัติการส่งข้อมูลที่มีชั้นความลับเป็นไปตามเอกสาร มาตรฐานจัดระดับชั้นความลับ การจัดทำป้าย และการจัดการข้อมูล

4.1.4 การคืนทรัพย์สิน

พนักงานและลูกจ้างของหน่วยงานทั้งหมดต้องคืนทรัพย์สินขององค์กรทั้งหมดที่ตนถือครองเมื่อสิ้นสุดการจ้างงาน หักสัญญา หรือสิ้นสุดข้อตกลงการจ้าง

4.2 การจัดประเภทของข้อมูลสารสนเทศ (Information classification)

4.2.1 ระดับชั้นความลับของข้อมูล

- ก) ให้ทำการจัดประเภทข้อมูลสารสนเทศ ลำดับความสำคัญหรือระดับชั้นความลับของข้อมูล รวมถึงระดับชั้นการเข้าถึง เวลาที่อนุญาตให้เข้าถึง และช่องทางการเข้าถึง ตามแนวทางในการจัดประเภทข้อมูล และการจัดการข้อมูล
- ข) เจ้าของเป็นผู้กำหนดระดับชั้นความลับของข้อมูล

4.2.2 การจัดทำป้ายข้อมูล

ข้อมูลจะต้องได้รับการจัดทำป้ายและจัดการในแง่ของการจัดเก็บ การขนส่ง การประมวลผล และการทำลายทิ้ง โดยเป็นไปตามแนวทางในการจัดประเภทข้อมูล และการจัดการข้อมูล

4.2.3 การจัดการทรัพย์สิน

- ก) สื่อบันทึกข้อมูลจะต้องได้รับการจัดประเภทของข้อมูลตามระดับความลับสูงสุดของข้อมูลที่มีอยู่ในสื่อบันทึกข้อมูลนั้น
- ข) การเปิดเผยหรือเผยแพร่ข้อมูลจะต้องสอดคล้องกับข้อกำหนดที่ระบุไว้ในแนวทางในการจัดประเภทข้อมูล และการจัดการข้อมูล

4.3 การจัดการสื่อบันทึกข้อมูล (Media Handling)

4.3.1 การบริหารจัดการสื่อบันทึกข้อมูลที่ถอดแยกหรือพกพาได้

สื่อบันทึกข้อมูลที่ถอดแยกหรือพกพาได้ ต้องมีการจัดการข้อมูลสารสนเทศที่อยู่ในสื่อบันทึกนั้นๆ โดยปฏิบัติแนวทางในการจัดประเภทข้อมูล และการจัดการข้อมูล

4.3.2 การทำลายสื่อบันทึกข้อมูลที่ไม่ใช้แล้วทิ้ง

สื่อบันทึกข้อมูลที่ล้าสมัยและไม่ใช้งานแล้วจะต้องถูกทำลายทิ้งตามมาตรฐานในการกำจัดสื่อบันทึกข้อมูล

4.3.3 การนำส่งสื่อสำรองข้อมูลออกไปยังภายนอกองค์กร (Physical Media Transfer)

- ก) สื่อบันทึกข้อมูลที่นำออกไปใช้ภายนอกองค์กร ต้องได้รับการป้องกันอย่างเหมาะสม
- ข) ผู้นำส่งสื่อบันทึกข้อมูล ต้องเป็นบุคคลหรือหน่วยงานที่ได้รับการรับรองและเชื่อถือได้

5. ความมั่นคงปลอดภัยทางกายภาพและสภาพแวดล้อม (Physical and environmental security)

ต้องมีการจัดแบ่งพื้นที่ออกเป็นอย่างน้อย ๒ พื้นที่ได้แก่ พื้นที่หวงห้าม (Secure areas) และพื้นที่ปฏิบัติงานทั่วไป โดยมีแนวทางปฏิบัติดังนี้

5.1 พื้นที่หวงห้าม (Secure areas)

5.1.1 อาณาเขตการรักษาความปลอดภัยทางกายภาพ

- ก) จะต้องกำหนดพื้นที่ที่ต้องมีการรักษาความมั่นคงปลอดภัยให้ชัดเจน
- ข) ต้องมีการจัดทำแผนผังที่ตั้งอาคารที่ใช้เป็นพื้นที่ในการปฏิบัติการ
- ค) ประตูและหน้าต่างที่อยู่ในพื้นที่ที่ต้องมีการรักษาความมั่นคงปลอดภัย จะต้องทำจากวัสดุที่แข็งแรง เพื่อป้องกันการบุกรุกจากภายนอก
- ง) จะต้องมีการควบคุมการเข้าออกพื้นที่ที่ต้องมีการรักษาความมั่นคงปลอดภัย

5.1.2 การควบคุมการเข้าออกทางกายภาพ

- ก) พนักงานที่ได้รับสิทธิในการเข้าออกพื้นที่หวงห้ามจะต้องเข้ากระบวนการลงทะเบียนและเพิกถอนสิทธิผู้ใช้งาน และจะได้รับการบันทึกลายนิ้วมือ (Finger Scan) เพื่อใช้ในการเข้าออกพื้นที่
- ข) ต้องมีการจัดทำและทบทวนรายชื่อผู้มีสิทธิเข้าออกพื้นที่หวงห้ามอย่างน้อยปีละ ๑ ครั้ง
- ค) ต้องมีการบันทึกรายละเอียดของผู้เข้าออกพื้นที่ทุกคนในสมุดบันทึกการเข้าออกของบุคคลภายนอกที่ไม่มีสิทธิในการเข้าออกพื้นที่หวงห้าม และผู้เข้าเยี่ยมต้องมีบัตรแสดงตนว่าเป็นผู้เข้าเยี่ยม และทำการคืนบัตรผ่านทันทีเมื่อเสร็จการเข้าเยี่ยม

5.1.3 การทำงานในพื้นที่หวงห้าม

- ก) การสื่อสารให้เจ้าหน้าที่กรมได้ทราบเกี่ยวกับลูกค้าหรือปัญหาภายในจะต้องทำเฉพาะกับข้อมูลซึ่งเจ้าหน้าที่กรมนั้น ๆ จำเป็นต้องใช้ในการปฏิบัติงานเท่านั้น
- ข) ไม่อนุญาตให้นำอุปกรณ์ถ่ายภาพ วิดีโอ เสียง หรืออุปกรณ์บันทึกอื่นๆ เข้ามาภายในบริเวณดังกล่าว เว้นแต่จะได้รับอนุญาต

- ค) ไม่อนุญาตให้ใช้อุปกรณ์เชื่อมต่อเคลื่อนที่ (เช่น โมเด็ม) ในขณะที่ยังเชื่อมต่อกับเครือข่ายขององค์กร
- ง) ระหว่างที่ผู้เข้าเยี่ยมชมอยู่ในพื้นที่หวงห้าม ต้องมีเจ้าหน้าที่กรมที่ได้รับสิทธิในการเข้าพื้นที่หวงห้ามคอยดูแลอยู่ตลอดเวลาที่เข้าพื้นที่หวงห้าม

5.1.4 การรักษาความปลอดภัยของพื้นที่ปฏิบัติงานทั่วไป

- ก) อาคารหรือพื้นที่ที่มีการดำเนินการที่เป็นความลับหรือสำคัญ (เช่น ห้องคอมพิวเตอร์) จะต้องไม่สามารถถูกล้ำเข้าไปได้ และจะแสดงวัตถุประสงค์ของพื้นที่ไว้เท่าที่จำเป็น จะต้องไม่มีป้ายหรือรายชื่อแสดงให้เห็นเด่นชัดว่าพื้นที่ที่ต้องมีการรักษาความมั่นคงปลอดภัยอยู่ที่ใด นอกจากนั้นในพื้นที่ดังกล่าวควรมีระดับการป้องกันที่เหมาะสมและต้องมีการควบคุมการผ่านเข้าออก
- ข) ในระหว่างช่วงที่ไม่มีผู้ดูแล จะต้องห้ามผ่านเข้าออกห้องทำงานหรือห้องที่มีระบบประมวลผลข้อมูลโดยจะต้องล็อกประตูและหน้าต่าง
- ค) สถานที่ปฏิบัติงานควรมีทางเข้าและทางออกมากนัก

5.1.5 การป้องกันภัยคุกคามจากภายนอกและสิ่งแวดล้อม

- ก) ห้องคอมพิวเตอร์จะต้องมีการควบคุมการเข้าออกอย่างเข้มงวด และตั้งอยู่ในพื้นที่ที่ปลอดภัยจากภัยทางธรรมชาติ เช่น ดินถล่ม หรือน้ำท่วม เป็นต้น
- ข) สถานที่ปฏิบัติงานควรมีอุปกรณ์ดับเพลิงที่เหมาะสม ในพื้นที่ที่มีความอ่อนไหวเป็นพิเศษ ควรพิจารณาติดตั้งระบบดับเพลิงอัตโนมัติ FM ๒๐๐ หรือเทียบเท่าด้วย
- ค) ควรทำการบำรุงรักษาพื้นที่โดยทั่วไปอย่างสม่ำเสมอเพื่อกำจัดขยะที่อาจติดไฟได้

5.1.6 พื้นที่สำหรับรับส่งสิ่งของ

- ก) การนำสิ่งของเข้าไปส่งในห้องคอมพิวเตอร์จะต้องมีการเตรียมการล่วงหน้า และมีการลงทะเบียนเมื่อเข้ามาในอาคารก่อน
- ข) วัสดุที่นำเข้ามาจะต้องผ่านการตรวจสอบว่ามีอันตรายหรือไม่ ก่อนที่จะเคลื่อนย้ายจากพื้นที่ขนถ่ายไปยังจุดที่จะมีการใช้งาน

5.2 การรักษาความปลอดภัยอุปกรณ์ (Equipment security)

5.2.1 การตั้งค่าและการป้องกันอุปกรณ์

- ก) ควรใช้ชั้นวางอุปกรณ์ (Server Rack) สำหรับวางเครื่องแม่ข่ายและอุปกรณ์เครือข่ายที่สำคัญๆ
- ข) การตั้งค่าความชื้นสัมพัทธ์ ระดับเตือนภัยและระดับวิกฤตสำหรับห้อง Data Centre ถูกระบุโดยกรมการทองเที่ยว
- ค) อุปกรณ์ควบคุมความชื้นสัมพัทธ์ต้องถูกใช้งานพร้อมกับสัญญาณเตือนภัยเมื่อความชื้นสัมพัทธ์ภายในห้อง Data Centre ถึงระดับวิกฤต

5.2.2 ความปลอดภัยของการเดินสาย

- ก) ควรมีการป้องกันสายเคเบิลที่มีข้อมูลวิ่งผ่านทั้งหมดเพื่อไม่ให้เกิดการดักจับข้อมูลหรือสร้างความเสียหายต่อสาย

- ข) ควรจะแยกสายไฟทั้งหมดออกจากสายเคเบิลสำหรับข้อมูลเพื่อป้องกันสัญญาณรบกวน
- ค) จุดเชื่อมต่อเครือข่าย (Network Termination Point) จะต้องมีการป้องกันทางกายภาพ และควบคุมการเข้าออก
- ง) สายเคเบิลควรมีการติดป้ายพร้อมระบุรหัสเป็นลายลักษณ์อักษร และมีการจัดอย่างเป็นระเบียบ
- จ) สายเคเบิลเครือข่ายต้องมีการป้องกันทางแม่เหล็กไฟฟ้า

5.2.3 การบำรุงรักษาอุปกรณ์

- ก) จะต้องทำการบันทึกงานซ่อมบำรุงอุปกรณ์ทั้งหมดที่เกิดขึ้น
- ข) ควรทำการบำรุงรักษาระบบควบคุมสภาพแวดล้อมและอุปกรณ์ต่างๆ ตามคำแนะนำที่ผู้ผลิตระบุไว้ รวมทั้งในระหว่างปิดระบบเพื่อบำรุงรักษาตามแผน
- ค) เฉพาะบุคลากรที่ผ่านการฝึกอบรมและได้รับอนุญาตเท่านั้นที่จะสามารถทำการซ่อมบำรุงระบบและอุปกรณ์ต่างๆ ในกรณีที่ให้บริการซ่อมบำรุงจากผู้ค้าจากภายนอก จะต้องกำหนดเงื่อนไขในการบำรุงรักษาอย่างละเอียด

5.2.4 การเคลื่อนย้ายทรัพย์สินออกนอกสำนักงาน

ทรัพย์สินที่มีการเคลื่อนย้ายโดยไม่ได้รับอนุญาตอาจนำไปสู่ปัญหาการขโมยทรัพย์สิน ซึ่งอาจจะนำไปสู่การเปิดเผยความลับของข้อมูลได้ ดังนั้นในการเคลื่อนย้ายอุปกรณ์ สื่อบันทึกข้อมูล และซอฟต์แวร์ จะต้องได้รับการอนุญาตอย่างเป็นทางการจากหัวหน้างานและควรจะมีการเก็บบันทึกการอนุญาตดังกล่าวด้วย

5.2.5 ความปลอดภัยของอุปกรณ์และทรัพย์สินซึ่งอยู่นอกสถานที่

เมื่อมีการนำอุปกรณ์และสื่อที่เคลื่อนย้ายได้ออกไปใช้นอกสถานที่ จะต้องมีการป้องกันโดยยึดตามนโยบายการใช้คอมพิวเตอร์แบบเคลื่อนที่และการปฏิบัติงานจากนอกสถานที่

5.2.6 การทำลายหรือนำอุปกรณ์กลับมาใช้อย่างปลอดภัย

จะต้องมีการกำหนดขั้นตอนอุปกรณ์เพื่อให้แน่ใจได้ว่าข้อมูลที่อยู่ในอุปกรณ์ดังกล่าวได้ถูกทำลายโดยที่ไม่สามารถกู้คืนกลับมาใช้ได้

5.2.7 อุปกรณ์ในกรณีที่ไม่มีผู้ใช้งาน (Unattended user equipment)

- ก) ผู้ใช้งานออกจากระบบสารสนเทศโดยทันทีเมื่อเสร็จสิ้นงาน หรือไม่อยู่หน้าจอเป็นเวลานาน
- ข) ผู้ใช้งานป้องกันผู้อื่นเข้าใช้เครื่องคอมพิวเตอร์หรือระบบสารสนเทศของตน โดยใส่รหัสผ่านได้ถูกต้องก่อนเข้าใช้งานเครื่องคอมพิวเตอร์
- ค) ผู้ใช้งานล็อคอุปกรณ์ที่สำคัญเมื่อไม่ได้ใช้งานหรือปล่อยทิ้งไว้โดยไม่มีดูแล
- ง) สร้างความตระหนักให้เกิดความเข้าใจในมาตรการป้องกันการเข้าถึงอุปกรณ์ในกรณีที่ไม่มีผู้ใช้งาน
- จ) เมื่อไม่มีผู้ใช้งานระบบสารสนเทศ ระบบจะยุติการใช้งานระบบสารสนเทศทันที

5.2.8 นโยบายในการเก็บโต๊ะทำงานและปิดหน้าจอ (Clear desk and clear screen policy)

- ก) บุคลากรต้องมั่นใจว่าไม่มีเอกสารสำคัญ หรือสื่อบันทึกดิจิทัลต่าง ๆ เช่น แผ่นซีดี เทปบันทึกข้อมูล วางไว้บนโต๊ะทำงานเมื่อจบการทำงานในแต่ละวัน หรือเมื่อไม่มีผู้ดูแลโต๊ะทำงานเป็นระยะเวลาหนึ่ง โดยให้จัดการตามประเภทข้อมูลที่กำหนดในแนวทางในการจัดประเภทข้อมูล และการจัดการข้อมูล
- ข) ผู้ใช้งานต้องตั้งค่าการใช้งานโปรแกรมถนอมหน้าจอ (Screensaver) เพื่อทำการล็อกหน้าจอภาพเมื่อไม่มีการใช้งาน (สูงสุด ๑๕ นาที) หลังจากนั้นเมื่อต้องการใช้งานผู้ใช้งานต้องใส่รหัสผ่าน (Password) เพื่อเข้าใช้งาน
- ค) ผู้ใช้งานต้องทำการลงบันทึกออก (Logout) ทันทีเมื่อเลิกใช้งานหรือไม่อยู่ที่หน้าจอเป็นเวลานาน

6. ความมั่นคงปลอดภัยสำหรับการดำเนินงาน (Operations security)

6.1 ขั้นตอนการปฏิบัติงานและหน้าที่ความรับผิดชอบ (Operational procedure and responsibilities)

6.1.1 กระบวนการในการปฏิบัติงานซึ่งกำหนดไว้เป็นลายลักษณ์อักษร

ต้องจัดทำขั้นตอนการปฏิบัติงานของระบบที่ใช้ในการปฏิบัติงานทั้งหมดเพื่อให้มั่นใจว่าจะมีการใช้งานอย่างเหมาะสมและปลอดภัย ขั้นตอนการปฏิบัติงานควรระบุถึงหัวข้อต่างๆ ที่เกี่ยวข้อง ดังต่อไปนี้

- ก) ขั้นตอนการปฏิบัติในการเปิดเครื่องและปิดเครื่อง พร้อมทั้งระบุหน้าที่รับผิดชอบออกมาในรูปเอกสาร
- ข) กำหนดการปฏิบัติงาน รวมถึงความเกี่ยวข้องกับระบบอื่นๆ เวลาอย่างรวดเร็วที่สุดที่จะเริ่มทำงานได้ และเวลาที่ช้าที่สุดที่จะสิ้นสุดงาน
- ค) โครงสร้างพื้นฐานของเทคโนโลยีสารสนเทศต้องมีการตั้งค่าอย่างปลอดภัยตามแนวทางความปลอดภัยเบื้องต้น (Hardening guideline) ก่อนนำไปใช้ในสภาพแวดล้อมการปฏิบัติงานจริง

6.1.2 การบริหารการเปลี่ยนแปลง

การเปลี่ยนแปลงใดๆ ของระบบ/ขั้นตอนการปฏิบัติงานต้องสอดคล้องกับกระบวนการบริหารการเปลี่ยนแปลงในการปฏิบัติงาน และมีแนวปฏิบัติที่สำคัญ ดังนี้

- ก) มีการขออนุมัติการเปลี่ยนแปลงก่อนดำเนินการทุกครั้ง
- ข) หลีกเลี่ยงการดำเนินงานในช่วงเวลาที่มีการใช้งานเป็นจำนวนมาก เพื่อหลีกเลี่ยงผลกระทบที่อาจเกิดขึ้นกับผู้ใช้งาน
- ค) ประเมินผลกระทบจากการเปลี่ยนแปลงและกำหนดแผนสำรองเพื่อใช้กู้คืน หากการดำเนินงานไม่สัมฤทธิ์ผล

6.1.3 การบริหารจัดการความสามารถของระบบ (Capacity management)

ต้องจัดให้มีการบริหารทรัพยากรสารสนเทศให้เพียงพอกับความต้องการใช้งานของระบบ

- ก) ควรมีการวางแผนระดับความต้องการทรัพยากรของระบบทั้งทรัพยากรที่สนับสนุนด้านเทคโนโลยีสารสนเทศและด้านกายภาพอย่างสม่ำเสมอ เพื่อให้มั่นใจว่าทรัพยากรของระบบที่ใช้งานอยู่เพียงพอที่จะรองรับปริมาณการใช้งานที่เพิ่มขึ้น
- ข) ควรจะกำหนดระดับการเตือนและระดับแจ้งเตือนเพื่อใช้เป็นจุดอ้างอิงในการปรับแต่งระบบต่อไป

6.1.4 การแบ่งแยกสภาพแวดล้อมสำหรับการปฏิบัติงาน การพัฒนา และการทดสอบ

- ก) ควรจะแยกซอฟต์แวร์ในการปฏิบัติงาน การพัฒนา และการทดสอบให้อยู่ในโดเมนหรือไดเรกทอรีที่ต่างกันออกไป
- ข) สภาพแวดล้อมในการปฏิบัติ การทดลอง และการพัฒนาต้องถูกแยกด้านตรรกะออกจากกัน และสภาพแวดล้อมของผู้ใช้ควรทำการดูแลแบบแยกส่วนกัน
- ค) ต้องลบบัญชีทดลอง และบัญชีผู้พัฒนาออกจากสภาพแวดล้อมการปฏิบัติงาน

6.2 การป้องกันซอฟต์แวร์ประสงค์ร้าย (Protection from malware)

6.2.1 เครื่องแม่ข่ายและเครื่องคอมพิวเตอร์

เครื่องแม่ข่ายและเครื่องคอมพิวเตอร์ทั้งหมดจะต้องติดตั้งและเปิดใช้งานซอฟต์แวร์ตรวจจับไวรัสที่ผ่านการอนุมัติแล้ว โดยจะต้องมีการปรับปรุงข้อมูลไวรัสให้ทันสมัยอย่างสม่ำเสมอ

6.2.2 พนักงานทุกคนจะต้องผ่านการฝึกอบรมความรู้และแนะนำเกี่ยวกับการป้องกันและจัดการไวรัส

6.2.3 ซอฟต์แวร์นั้นครอบคลุมถึง freeware, shareware และซอฟต์แวร์ลิขสิทธิ์

ผู้ใช้งานจะต้องติดตั้งซอฟต์แวร์ที่ได้รับการอนุมัติล่วงหน้าแล้วเท่านั้น หากซอฟต์แวร์นั้น ไม่อยู่ในเอกสารรายชื่อซอฟต์แวร์ที่ได้รับการอนุมัติล่วงหน้า จะต้องได้รับการอนุญาตจากผู้บริหารก่อนทำการติดตั้ง

6.3 การสำรองข้อมูล (Backup)

- 6.3.1 จะต้องมีการสำรองข้อมูลเป็นประจำตามนโยบายการสำรองข้อมูล
- 6.3.2 ควรมีการกำหนดขั้นตอนในการสำรองข้อมูลที่จะนำมาใช้งาน
- 6.3.3 ข้อมูลแต่ละส่วนควรมีช่วงเวลาแนะนำในการเก็บรักษาข้อมูลที่เป็นไปตามข้อกำหนดทางธุรกิจ
- 6.3.4 กลยุทธ์การสำรองข้อมูลต้องเป็นไปตามช่วงเวลาการเก็บรักษาข้อมูลเฉพาะที่ระบุในตารางการเก็บรักษาข้อมูล
- 6.3.5 ข้อมูลที่เก็บบนระบบ ICT และข้อมูลที่เก็บบนสื่อบันทึกสำรองต้องเป็นไปตาม หรือมากกว่าที่ระบุไว้ในช่วงเวลาการเก็บรักษาข้อมูล
- 6.3.6 กลยุทธ์การสำรองข้อมูลต้องเป็นไปตามความพร้อมใช้งาน และข้อกำหนดด้านความต่อเนื่องทางธุรกิจในส่วนความเร็วในการกู้คืน และจำนวนข้อมูลที่ยอมให้สูญเสียได้มากที่สุด หากเกิดเหตุการณ์วิกฤติ (RPO)

6.4 การบันทึกข้อมูลล็อกและการเฝ้าระวัง (Logging and monitoring)

6.4.1 การติดตามตรวจสอบการใช้งานของผู้ใช้

- ก) ในการตรวจสอบผู้ใช้งานระบบ จะต้องมีการเปิดบันทึกข้อมูลผู้ใช้งาน ซึ่งแบ่งออกเป็นระดับระบบปฏิบัติการและระดับโปรแกรม โดยจะต้องประกอบไปด้วยข้อมูลอย่างน้อยดังต่อไปนี้
 - ๑) รหัสประจำตัวผู้ใช้
 - ๒) วันที่และเวลาที่เข้าใช้งานและออกจากการใช้งาน
 - ๓) เครื่องหรือตำแหน่งที่ใช้ในการเข้าใช้งาน หากสามารถระบุได้
 - ๔) บันทึกการพยายามเข้าใช้งานระบบทั้งที่ประสบความสำเร็จและที่ถูกปฏิเสธ
 - ๕) บันทึกการพยายามเข้าใช้งานโปรแกรมทั้งที่ประสบความสำเร็จและที่ถูกปฏิเสธ หากสามารถทำได้
 - ๖) บันทึกการพยายามเข้าใช้งานข้อมูลและทรัพยากรอื่นๆ ทั้งที่ประสบความสำเร็จและที่ถูกปฏิเสธ
- ข) การเปิดบันทึกจะต้องสามารถตรวจสอบกิจกรรมที่เกิดขึ้นจากผู้ใช้แต่ละคนได้ ซึ่งรวมไปถึงเจ้าหน้าที่ดูแลระบบที่มีหน้าที่ดูแลจัดการเครื่องแม่ข่าย

6.4.2 การป้องกันบันทึกข้อมูล

ควรมีการป้องกันบันทึกข้อมูลการใช้งานจากการเปลี่ยนแปลงโดยไม่ได้รับอนุญาตและควรมีการบันทึกการเข้าใช้งานบันทึกข้อมูลการใช้งานด้วย

6.4.3 บันทึกการดำเนินการของผู้ดูแลระบบและผู้ใช้งาน

- ก) จะต้องมีการบันทึกการใช้งานผ่านสิทธิพิเศษของผู้ดูแลระบบ
- ข) จะต้องมีการบันทึกการบริหารจัดการผู้ใช้งานจัดทำโดยผู้ดูแลระบบ

6.4.4 การตั้งเวลาให้ตรงกัน

ควรมีการตั้งเวลาของระบบทั้งหมดให้ตรงกันเพื่อช่วยในการวิเคราะห์ลำดับการเกิดขึ้นของเหตุการณ์

6.5 การควบคุมการติดตั้งซอฟต์แวร์บนระบบให้บริการ (Control of operational software)

6.5.1 การควบคุมซอฟต์แวร์ที่ใช้ในการปฏิบัติงาน

- ก) การปรับปรุงรายการซอฟต์แวร์ดำเนินงานซึ่งสนับสนุนหน้าที่สำคัญต่างๆ ต้องกระทำโดยเจ้าหน้าที่ที่ได้รับแต่งตั้งเท่านั้น และต้องบันทึกความเคลื่อนไหวทั้งหมดของรายการโปรแกรมที่ใช้ในการดำเนินงาน
- ข) ต้องกำหนดกระบวนการตรวจสอบรายชื่อซอฟต์แวร์ที่ใช้ในการดำเนินงาน

6.6 การบริหารจัดการช่องโหว่ทางเทคนิค (Technical vulnerability management)

6.6.1 ต้องมีการระบุบทบาทและหน้าที่ความรับผิดชอบ รวมไปถึงการเฝ้าระวังช่องโหว่ การประเมินความเสี่ยง การปิดช่องโหว่ การติดตามทรัพย์สิน และการประสานงานอื่นๆ ที่จำเป็น

6.6.2 ต้องกำหนดขั้นตอนการจัดการตัวแก้ไขซอฟต์แวร์เพื่อการบริหารตัวปรับปรุงประสิทธิภาพด้านความปลอดภัยของระบบปฏิบัติการโปรแกรม

6.7 สิ่งที่ต้องพิจารณาในการตรวจสอบระบบ (Information systems audit considerations)

6.7.1 การควบคุมการตรวจสอบระบบข้อมูล

- ก) ขอบเขตการตรวจสอบระบบต้องได้รับความเห็นชอบและการควบคุมเพื่อให้มั่นใจว่าการเข้าใช้งานเพื่อตรวจสอบจะถูกจำกัดขอบเขตตามขอบเขตงานที่ตกลงกัน
- ข) การตรวจสอบระบบต้องดำเนินการตามความคิดเห็นทางด้านการตรวจสอบระบบ กระบวนการ ข้อกำหนด และหน้าที่ความรับผิดชอบในการตรวจสอบระบบต้องทำเป็นลายลักษณ์อักษร
- ค) ต้องวางแผนถึงข้อกำหนดในการตรวจสอบระบบ และกิจกรรมต่างๆ ที่เกี่ยวข้องกับการตรวจเช็คซอฟต์แวร์และข้อมูลปฏิบัติการ และต้องได้รับความเห็นชอบจากผู้บริหารที่เกี่ยวข้องเพื่อที่จะลดความเสี่ยงของเหตุไม่พึงประสงค์ที่อาจเกิดขึ้นได้ ข้อกำหนดสำหรับการดำเนินการพิเศษ หรือเพิ่มเติมใดๆ ต้องถูกระบุและได้รับความเห็นชอบเช่นกัน
- ง) ขอบเขตการตรวจเช็คระบบต้องได้รับความเห็นชอบและควบคุม เพื่อที่จะมั่นใจได้ว่าการเข้าถึงการตรวจสอบนั้นอยู่ภายใต้ขอบเขตที่วางไว้
- จ) ต้องมีการระบุทรัพยากรเทคโนโลยีสารสนเทศที่ใช้ในการตรวจสอบระบบ และต้องพร้อมใช้งานเสมอ
- ฉ) ทำการตรวจสอบระบบด้วยซอฟต์แวร์และข้อมูลอ่านอย่างเดียวเท่านั้น ไม่สามารถแก้ไขและบันทึกทับได้
- ช) การอนุญาตให้เข้าถึงไฟล์ที่นอกเหนือจากไฟล์อ่านอย่างเดียวนั้น สามารถทำได้ในการแยกสำเนาของไฟล์ระบบเท่านั้น ที่จะถูกลบทันทีเมื่อการตรวจสอบเสร็จสิ้น

- ข) การเข้าถึงระหว่างมีการตรวจสอบระบบนั้น จะต้องมีการเฝ้าระวัง และ บันทึกไว้เพื่ออ้างอิง

7. ความมั่นคงปลอดภัยสำหรับการสื่อสารข้อมูล (Communications security)

7.1 การบริหารจัดการความมั่นคงปลอดภัยของเครือข่าย (Network security management)

7.1.1 การควบคุมเครือข่าย

- ก) ควรมีการป้องกันเครือข่ายจากการบุกรุกโดยไม่ได้รับอนุญาตผ่านทางวิธีการจัดรูปแบบของเครือข่าย (Topology) การเลือกเส้นทางของข้อมูล (Routing) ความสามารถในการเชื่อมต่อConnectivity) และการควบคุมการเข้าใช้งาน (Access Control)
- ข) ควรจัดทำเอกสารแสดงผังการเชื่อมต่อของเครือข่าย และปรับปรุงให้ทันสมัยอยู่เสมอเมื่อมีการเปลี่ยนแปลงเครือข่าย
- ค) อนุญาตให้เฉพาะเครื่องคอมพิวเตอร์หรืออุปกรณ์ที่เกี่ยวข้องกับการดำเนินงานขององค์กรที่ได้รับอนุญาตเท่านั้นในการเชื่อมต่อกับระบบเครือข่าย

7.1.2 ความมั่นคงปลอดภัยในการให้บริการเครือข่าย

- ก) การใช้งานบริการเครือข่าย ต้องกำหนดให้ผู้ใช้งานสามารถเข้าถึงระบบสารสนเทศได้แต่เพียงบริการที่ได้รับอนุญาตให้เข้าถึงเท่านั้น
- ข) ต้องมีการยืนยันตัวตนบุคคลสำหรับผู้ใช้ที่อยู่ภายนอกองค์กร (user authentication for external connections) ต้องกำหนดให้มีการยืนยันตัวตนบุคคลก่อนที่จะอนุญาตให้ผู้ใช้ที่อยู่ภายนอกองค์กรสามารถเข้าใช้งานเครือข่ายและระบบสารสนเทศขององค์กรได้

7.1.3 การแบ่งแยกเครือข่าย

ต้องมีการจัดแบ่งกลุ่มเครือข่ายตามกลุ่มของบริการสารสนเทศ กลุ่มผู้ใช้งาน และกลุ่มของระบบสารสนเทศ

7.2 การถ่ายโอนสารสนเทศ

7.2.1 นโยบายและขั้นตอนปฏิบัติสำหรับการแลกเปลี่ยนข้อมูลและซอฟต์แวร์

เพื่อให้การแลกเปลี่ยนข้อมูลสารสนเทศทั้งในและนอกองค์กร มีความมั่นคงปลอดภัยเป็นไปตามระดับชั้นความลับของข้อมูล จึงได้จัดทำข้อกำหนดในการแลกเปลี่ยนข้อมูลสารสนเทศ ดังนี้

- ก) การแลกเปลี่ยนข้อมูลสารสนเทศในองค์กร
 - ๑) การแลกเปลี่ยนข้อมูลสารสนเทศภายในองค์กรจะต้องปฏิบัติตามข้อกำหนดเอกสารการจัดระดับชั้นความลับ และการจัดการข้อมูลสารสนเทศขององค์กร
- ข) การแลกเปลี่ยนข้อมูลสารสนเทศระหว่างองค์กร
 - ๑) เจ้าหน้าที่ที่เกี่ยวข้องกับการจัดทำข้อกำหนดเกี่ยวกับการแลกเปลี่ยนข้อมูลสารสนเทศระหว่างองค์กร ประเมินความเสี่ยงของการเข้ามาใช้ข้อมูลจากหน่วยงานภายนอก โดยพิจารณาประเด็นต่างๆ ดังต่อไปนี้

- รูปแบบของการเข้าถึงข้อมูลสารสนเทศ
- ประเภทของข้อมูลสารสนเทศที่ต้องการใช้ในการแลกเปลี่ยน
- มาตรฐานทางเทคนิคในการบันทึกและอ่านข้อมูลสารสนเทศ ตลอดจนซอฟต์แวร์ที่เกี่ยวข้อง
- ข้อมูลหรือซอฟต์แวร์ที่ต้องการจะส่ง หรือมาตรการ/ กระบวนการในการแลกเปลี่ยนสื่อบันทึกข้อมูล
- มาตรการอื่นๆ ที่จำเป็นในการป้องกันข้อมูลที่สำคัญ เช่น การใช้กุญแจในการเข้ารหัสข้อมูล เป็นต้น
- ทบทวนมาตรการ (Controls) ตามที่ได้กำหนดไว้สำหรับการเข้าออกสถานที่ ตลอดจนการเข้าถึงระบบ หากมีความจำเป็นอาจเพิ่มมาตรการเพื่อลดความเสี่ยงที่มีแนวโน้มว่าจะเกิดขึ้น ทั้งนี้มาตรการทั้งหมดควรต้องได้รับการวางแผนและนำมาใช้อย่างเป็นทางการต่อไป

๒) ต้องมีสัญญาหรือข้อตกลงเพื่อระบุความรับผิดชอบของฝ่ายที่รับข้อมูล รวมทั้งระบุมาตรฐานในบรรจุเอกสารหรือข้อมูล และการส่งอย่างชัดเจน

7.2.2 ข้อตกลงสำหรับการถ่ายโอนสารสนเทศ

การถ่ายโอนสารสนเทศระหว่างองค์กรกับหน่วยงานภายนอกทั้งหมด จะต้องเข้าร่วมลงนามในสัญญาที่ว่าด้วยข้อกำหนดด้านความมั่นคงปลอดภัยในการแลกเปลี่ยนข้อมูลสารสนเทศ รวมถึง

- ก) การจัดส่งข้อมูล และ/หรือ ซอฟต์แวร์
- ข) การจัดการแลกเปลี่ยนสื่อบันทึกข้อมูล

7.2.3 การใช้งานระบบจดหมายอิเล็กทรอนิกส์

- ก) ให้ผู้บริหาร ข้าราชการ พนักงานราชการ และเจ้าหน้าที่ของกรมการท่องเที่ยวทุกคนใช้ระบบจดหมายอิเล็กทรอนิกส์ (E-Mail) ของกรมการท่องเที่ยว เพื่อการทำงานตามภารกิจหน้าที่ความรับผิดชอบของตนเอง และติดต่อกับหน่วยงานทั้งภายในและภายนอก
- ข) การส่งหนังสือราชการ เอกสาร และข้อมูลที่มีเนื้อหาของทางราชการผ่านทางระบบจดหมายอิเล็กทรอนิกส์นั้น ให้ข้าราชการ พนักงานราชการ และเจ้าหน้าที่กรมการท่องเที่ยวทุกคน จัดส่งเอกสารผ่านทางระบบจดหมายอิเล็กทรอนิกส์ของกรมการท่องเที่ยว (@tourism.go.th) เท่านั้น และห้ามให้ระบบจดหมายอิเล็กทรอนิกส์ของเอกชนในการส่งเอกสารหรือข้อมูลต่างๆ ของราชการโดยเด็ดขาด
- ค) ผู้บริหาร ข้าราชการ พนักงานราชการ และเจ้าหน้าที่ของกรมการท่องเที่ยว ไม่ควรใช้ข้อความที่ไม่สุภาพหรือรับส่งจดหมายอิเล็กทรอนิกส์ที่ไม่เหมาะสม หรือข้อมูลอันอาจทำให้เสียชื่อเสียงของกรมการท่องเที่ยว ทำให้เกิดความแตกแยกระหว่างองค์กรผ่านทางจดหมายอิเล็กทรอนิกส์
- ง) ผู้บริหาร ข้าราชการ พนักงานราชการ และเจ้าหน้าที่ของกรมการท่องเที่ยว ไม่ควรส่งต่อจดหมายอิเล็กทรอนิกส์ลูกโซ่ หรือสแปมจดหมายอิเล็กทรอนิกส์ซึ่งเป็นสิ่งที่ไม่สมควรทำบนเครือข่ายอินเทอร์เน็ต
- จ) ผู้บริหาร ข้าราชการ พนักงานราชการ และเจ้าหน้าที่ของกรมการท่องเที่ยว ไม่ควรส่งต่อจดหมายอิเล็กทรอนิกส์ที่เกี่ยวกับการล่วงละเมิดหรือข่มขู่ หรือมีเนื้อหาข้อความที่ขัดต่อ

กฎหมายและศีลธรรม และใช้จดหมายอิเล็กทรอนิกส์เป็นเครื่องมือในการกระจายข่าวสาร
เว้นแต่เป็นการประกาศที่เหมาะสม

7.2.4 ข้อตกลงในการรักษาความลับ

หน่วยงานภายนอกที่อยู่ในขอบเขตการดำเนินงาน ISMS จะต้องลงนามในสัญญาการรักษา
ข้อมูลที่เป็นความลับสำหรับหน่วยงานภายนอก

8. การจัดหา การพัฒนา และการบำรุงรักษาระบบข้อมูล (System acquisition, development and maintenance)

8.1 ข้อกำหนดด้านความปลอดภัยของระบบ (Security requirements of information system)

8.1.1 การวิเคราะห์และข้อกำหนดความต้องการด้านความมั่นคงปลอดภัยสารสนเทศ

- ก) ข้อกำหนดด้านความปลอดภัยสารสนเทศต้องมีการประเมินในระหว่างขั้นตอนการกำหนด
ความต้องการของผู้ใช้งาน ข้อกำหนดด้านความปลอดภัยอย่างต่ำควรประกอบด้วยด้านต่าง ๆ
ต่อไปนี้
 - ๑) การระบุและการตรวจสอบยืนยันตัวบุคคลของผู้ใช้งาน
 - ๒) การควบคุมการเข้าถึงและการอนุญาตให้ใช้งาน
 - ๓) การป้องกันความลับและความสมบูรณ์ครบถ้วนของรายการเปลี่ยนแปลงหรือข้อมูล
 - ๔) ข้อกำหนดการตรวจสอบ
 - ๕) ข้อกำหนดของกฎหมาย หน่วยงานกำกับดูแล และการปฏิบัติให้เป็นไปตามกฎหมาย

8.1.2 ความมั่นคงปลอดภัยของบริการสารสนเทศบนเครือข่ายสาธารณะ

- ก) มาตรการทางเทคนิคที่ใช้ในการจัดการความมั่นคงปลอดภัยควรมีการตกลงร่วมกัน
ระหว่างคู่ค้าและผู้ให้บริการ
- ข) ข้อตกลงควรจัดทำร่วมกันเพื่อให้ทุกฝ่ายที่เกี่ยวข้องเข้าใจถึงหน้าที่ความรับผิดชอบและข้อ
ผูกพันการใช้ข้อมูลร่วมกันในการทำธุรกรรม
- ค) ควรมีการจัดทำข้อตกลงและเงื่อนไขการซื้อขายระหว่างธุรกิจและผู้ซื้อ
- ง) ข้อตกลงควรมีการระบุข้อผูกพันของทุกฝ่ายที่เกี่ยวข้องหากเกิดกรณีการชำระเงินเท็จ หรือ
เกิดการไม่ส่งมอบบริการ
- จ) การเข้าถึงบริการทางการเงินควรมีการกำหนด ดูแล และควบคุม โดยจะต้องมีการ
พิจารณาระดับในการเข้าถึง (Authentication Level) ด้วยการประเมินความเสี่ยงจาก
ความต้องการทางธุรกิจ
- ฉ) Audit Trails จะต้องได้รับการดูแลและควบคุมไม่ให้มีการแก้ไขเพื่อใช้ในการตรวจสอบ
กิจกรรมธุรกรรมพาณิชย์อิเล็กทรอนิกส์
- ช) องค์กรควรใช้ระบบตามการใช้สถาปัตยกรรมเครือข่ายแบบ n-tier เพื่อแบ่งแยกการ
นำเสนอ การประมวลผลแอปพลิเคชัน และฟังก์ชันการบริหารจัดการข้อมูล
- ซ) ในกรณีที่มีการให้บริการบนเครือข่ายสาธารณะ ระบบแรกที่มีการติดต่อต้องทำการตรวจ
เพื่อให้มั่นใจว่าผู้ใช้ได้รับการอนุมัติก่อนเริ่มการใช้บริการ

8.2 ความมั่นคงปลอดภัยสำหรับกระบวนการพัฒนาและสนับสนุน (Security in development and support processes)

8.2.1 นโยบายการพัฒนาระบบให้มีความมั่นคงปลอดภัย

- ก) นักพัฒนาระบบจำเป็นต้องศึกษาวงจรการพัฒนาระบบ และ เทคนิคในการเขียนระบบให้มีความปลอดภัยให้ดี
- ข) องค์กรต้องนำหลักการของวงจรการพัฒนาระบบมาใช้ เพื่อให้มั่นใจได้ถึงคุณภาพของซอฟต์แวร์ในการพัฒนาระบบ

8.2.2 ขั้นตอนปฏิบัติสำหรับควบคุมการเปลี่ยนแปลงระบบ

- ก) การเปลี่ยนแปลงระบบ จะต้องถูกควบคุมโดยกระบวนการควบคุมการเปลี่ยนแปลงอย่างเป็นทางการ เพื่อลดปัญหากระทบกับระบบโดยรวม
- ข) คำร้องขอการเปลี่ยนแปลงระบบหรือซอฟต์แวร์ทุกคำร้องต้องได้รับการอนุมัติจากเจ้าของระบบ หรือบุคคลที่ได้รับแต่งตั้งก่อนเริ่มทำการเปลี่ยนแปลง

8.2.3 การทบทวนโปรแกรมทางด้านเทคนิคหลังจากมีการเปลี่ยนแปลงระบบปฏิบัติการ

- ก) เมื่อมีการเปลี่ยนแปลง แก๊ซ หรือมีการปรับปรุงประสิทธิภาพของระบบปฏิบัติการ ควรแจ้งให้ทราบล่วงหน้าเพื่อให้มีเวลาพอสำหรับทบทวนและทดสอบระบบโปรแกรมก่อนใช้งานจริง และให้มั่นใจว่าไม่มีผลกระทบร้ายแรงต่อการทำงานของผู้ใช้งานหรือส่งผลกระทบต่อความมั่นคงปลอดภัย
- ข) การเปลี่ยนแปลงระบบปฏิบัติการต้องเข้าสู่กระบวนการดำเนินงานเพื่อบริหารการเปลี่ยนแปลง

8.2.4 การจำกัดการเปลี่ยนแปลงซอฟต์แวร์สำเร็จรูป

- ก) ห้ามมิให้มีการเปลี่ยนแปลงใดๆ บนซอฟต์แวร์สำเร็จรูป
- ข) จะต้องได้รับคำยินยอมจากผู้ขายก่อนทำการเปลี่ยนแปลงใดๆ เพื่อให้มั่นใจว่าไม่มีการละเมิดทรัพย์สินทางปัญญา
- ค) การเปลี่ยนแปลงตามความต้องการของผู้ซื้อซอฟต์แวร์มาตรฐาน จะต้องได้รับการสนับสนุนจากผู้ให้บริการ
- ง) ต้องไม่ทำการแก้ไขโปรแกรมสำเร็จรูปจากผู้ขายถ้าไม่จำเป็น

8.2.5 การพัฒนาระบบโดยหน่วยงานภายนอก

- ก) ซอฟต์แวร์ที่พัฒนาโดยหน่วยงานภายนอกต้องบรรลุตามรายละเอียดข้อกำหนดผู้ใช้ และมีการสนับสนุนด้านสินค้าอย่างเหมาะสม
- ข) ต้องมั่นใจว่ามีการปรึกษาและทำการตกลงร่วมกันระหว่างองค์กรและหน่วยงานภายนอกในเรื่องการสนับสนุนจากหน่วยงานภายนอก และการปฏิบัติตามกฎหมายอย่างต่อเนื่องการจัดการใบอนุญาต กรรมสิทธิ์ของโปรแกรม และทรัพย์สินทางปัญญา

8.2.6 การทดสอบด้านความมั่นคงปลอดภัยของระบบ

ต้องมีการดำเนินการทดสอบคุณสมบัติด้านความมั่นคงปลอดภัยของระบบในระหว่างที่ระบบอยู่ในช่วงการพัฒนา

8.2.7 การตรวจรับระบบ

- ก) จะต้องมีการเกณฑ์ในการตรวจรับระบบทุกระบบที่มีการพัฒนาขึ้นมาใหม่หรือมีการปรับปรุงประสิทธิภาพเพิ่มเติม โดยเกณฑ์ที่ใช้ในการตรวจรับจะต้องเป็นเกณฑ์ที่กำหนดอย่างละเอียด ผ่านการอนุมัติ มีการจัดทำเป็นเอกสาร และผ่านการทดสอบการใช้งานมาแล้ว
- ข) การทดสอบเพื่อตรวจรับระบบจะต้องไม่ทำโดยทีมที่เป็นผู้พัฒนาระบบนั่นเอง

8.3 ข้อมูลสำหรับการทดสอบ (Test data)

8.3.1 การป้องกันข้อมูลสำหรับการทดสอบ

- ก) ต้องได้รับการอนุญาตก่อนนำสำเนาข้อมูลปฏิบัติการไปใช้ในการทดสอบระบบทุกครั้ง
- ข) ต้องมีการเปลี่ยนแปลงข้อมูลบางส่วนสำหรับข้อมูลที่น่าไปทดสอบ ไม่ให้เหมือนข้อมูลต้นทาง เพื่อป้องกันหากข้อมูลรั่วไหลและถูกนำไปใช้โดยไม่ได้รับอนุญาต
- ค) ต้องดำเนินการให้สิทธิขั้นต่ำ (Least privilege) หมายถึง จำกัดผู้ใช้ที่ทำงาน, ข้อมูลและระบบข้อมูล เฉพาะที่จำเป็นในการทำงานเท่านั้น

9. ความสัมพันธ์กับผู้ให้บริการภายนอก (Supplier relationships)

9.1 ความมั่นคงปลอดภัยสารสนเทศกับความสัมพันธ์กับผู้ให้บริการภายนอก (Information security in supplier relationship)

9.1.1 นโยบายความมั่นคงปลอดภัยสารสนเทศด้านความสัมพันธ์กับผู้ให้บริการภายนอกผู้ให้บริการต้องได้รับการจัดการตาม วงจรการให้บริการ ดังนี้

- การวางแผน
- ข้อผูกพัน
- การนำไปปฏิบัติ
- การแก้ไข/เปลี่ยนแปลง
- การสิ้นสุดการให้บริการงาน
- ก) ในระยะการวางแผน องค์กรควรระบุความต้องการการจัดจ้างคนภายนอก, ความเสี่ยงที่จะเกิดขึ้นในการจ้างคนภายนอก และปัจจัยที่สามารถเป็นไปได้ในการลดการจัดจ้างคนภายนอก รายละเอียดเหล่านี้จะต้องทำเป็นลายลักษณ์อักษรในส่วนของบริหารจัดการโปรเจก
- ข) ข้อผูกพัน องค์กรควรเลือกและประเมินหาผู้ให้บริการเพื่อที่จะรักษาความมั่นคงปลอดภัยสารสนเทศให้เป็นไปตามทัศนคติขององค์กร โดยที่มีการระบุการจัดการด้านความมั่นคงปลอดภัยอย่างละเอียดในสัญญา

- ค) การนำไปปฏิบัติ องค์กรต้องพัฒนาการรักษาความมั่นคงปลอดภัยสารสนเทศ และตารางสมรรถนะโดยอ้างอิงตามสัญญาและเงื่อนไขที่กำหนดไว้ ตารางนั้นจะต้องมีการเฝ้าระวังและทบทวนเป็นประจำ
- ง) การแก้ไข/เปลี่ยนแปลง องค์กรต้องทำการแก้ไขสัญญาการบริการ และ/หรือหน้าที่ในด้านความมั่นคงปลอดภัยสารสนเทศ การกระทำดังกล่าวต้องเป็นไปตามสัญญาผูกมัดของผู้ให้บริการ
- จ) การสิ้นสุดการให้บริการ องค์กรต้องเตรียมให้ผู้ให้บริการส่งหน้าที่ความรับผิดชอบกลับมายังองค์กรหรือผู้ให้บริการรายใหม่ องค์กรต้องมั่นใจได้ว่าข้อมูลขององค์กรทั้งหมดต้องได้กลับคืนจากผู้ให้บริการรายเดิม รายละเอียดเหล่านี้จะต้องทำเป็นลายลักษณ์อักษรในส่วนของการบริหารจัดการโปรเจก

9.1.2 การระบุปัญหาด้านความปลอดภัยในข้อตกลงกับบุคคลภายนอก

ข้อตกลงกับบุคคลภายนอกจะต้องระบุถึงการให้ความสำคัญกับความปลอดภัยที่เกี่ยวข้องดังต่อไปนี้

- ก) การจัดหมวดหมู่ข้อมูลและการจัดการกับข้อมูล
- ข) ระดับเป้าหมายของการให้บริการที่ยอมรับได้
- ค) ความรับผิดชอบของทั้งสองฝ่าย
- ง) การป้องกันสิทธิในทรัพย์สินทางปัญญา (IPR) และลิขสิทธิ์ของงานที่ทำร่วมกัน
- จ) การจัดการการควบคุมการเข้าใช้งานทั้งแบบเข้ามาใช้ถึงตัวเครื่องและแบบผ่านทางระบบเครือข่าย (รวมถึงการเข้าใช้งานแบบพิเศษ)
- ฉ) สิทธิในการตรวจสอบความรับผิดชอบตามสัญญาหรือการตรวจสอบที่ดำเนินการโดยบุคคลที่สาม
- ช) การเกี่ยวข้องของบุคคลภายนอกโดยกับผู้รับจ้างช่วงอื่น
- ซ) ข้อกำหนดในการเก็บรักษาไว้ซึ่งรายชื่อของผู้ที่ได้รับอนุญาตให้บริการ และสิทธิอื่นๆ
- ฌ) สิทธิในการเฝ้าระวังและยกเลิกกิจกรรมของผู้ใช้
- ญ) ข้อกำหนดในการทำสำเนา และเปิดเผยข้อมูลองค์กร
- ฎ) การคืน หรือการทำลายข้อมูลต่างๆเมื่อสัญญาจบสิ้น
- ฏ) ข้อกำหนดในการป้องกันซอฟต์แวร์ประสงค์ร้าย

9.2 การบริหารจัดการการให้บริการโดยผู้ให้บริการภายนอก

9.2.1 การติดตามและทบทวนบริการของผู้ให้บริการภายนอก

- ก) การส่งมอบบริการโดยบุคคลที่สามจากภายนอกควรจะมีการตกลงทำสัญญารักษาความปลอดภัย คำนิยามของบริการ และระดับของการส่งมอบบริการรวมอยู่ในสัญญาส่งมอบบริการจากบุคคลภายนอก
- ข) ควรจัดให้มีการตรวจสอบติดตามและประเมินผลการบริการจากบุคคลภายนอกเป็นประจำเพื่อให้มั่นใจว่าได้มีการปฏิบัติตามข้อตกลงในการรักษาความมั่นคงปลอดภัยของข้อมูล และเพื่อให้ได้มีการจัดการกับปัญหาทางด้านความปลอดภัยอย่างเหมาะสม

9.2.2 การบริหารการเปลี่ยนแปลงในบริการจากผู้ให้บริการภายนอก

- ก) องค์กรจะต้องสร้างความยืดหยุ่นในสัญญาการให้บริการเมื่อมีการเปลี่ยนแปลงข้อกำหนดในการให้บริการ ซึ่งรวมถึงการดูแลและปรับปรุงนโยบาย ขั้นตอนปฏิบัติ และการควบคุมด้านความมั่นคงปลอดภัยของข้อมูลที่มีอยู่เดิม
- ข) ระหว่างทำการเปลี่ยนแปลงการให้บริการ ต้องมีการปรึกษากันถึงความเสี่ยงที่อาจเกิดขึ้นจากการเปลี่ยนแปลงการให้บริการ

10. การบริหารจัดการเหตุการณ์ด้านความมั่นคงปลอดภัยสารสนเทศ (Information security incident management)

10.1 การบริหารจัดการเหตุการณ์ด้านความมั่นคงปลอดภัยสารสนเทศและการปรับปรุง (Management of information security incidents and improvements)

10.1.1 หน้าที่รับผิดชอบและขั้นตอนปฏิบัติ

ต้องมีการกำหนดขั้นตอนการจัดการเหตุการณ์และจุดอ่อนทางด้านความปลอดภัยข้อมูลเพื่อจัดการเหตุการณ์ในหลายๆ ลักษณะที่เกิดขึ้น

- ก) ระบบข้อมูลขัดข้อง และใช้บริการไม่ได้
- ข) โปรแกรมประสงค์ร้ายต่อระบบ
- ค) การถูกโจมตีที่ทำให้เครื่องเป้าหมายไม่สามารถให้บริการได้
- ง) ความผิดพลาดอันเป็นผลจากข้อมูลทางธุรกิจที่ไม่สมบูรณ์หรือไม่ถูกต้อง
- จ) การล่วงละเมิดความลับและความครบถ้วนสมบูรณ์ของข้อมูล
- ฉ) การใช้ระบบข้อมูลโดยมิชอบ

10.1.2 การรายงานเหตุการณ์ทางด้านความมั่นคงปลอดภัยของข้อมูล

- ก) ต้องกำหนดช่องทางที่ใช้รายงานเหตุการณ์ทางด้านความปลอดภัย และแจ้งให้ผู้ใช้งานทุกคนทราบ
- ข) ทุกเหตุการณ์ทางด้านความปลอดภัยต้องรายงานขึ้นไปตามกระบวนการรายงานเหตุการณ์และจุดอ่อนทางด้านความปลอดภัย

10.1.3 การรายงานจุดอ่อนทางด้านความมั่นคงปลอดภัยสารสนเทศ

- ก) ต้องกำหนดช่องทางที่ใช้ในรายงานจุดอ่อนทางด้านความปลอดภัย และแจ้งให้ผู้ใช้งานทุกคนทราบ
- ข) จุดอ่อนทางด้านความปลอดภัยต้องรายงานขึ้นไปตามกระบวนการรายงานเหตุการณ์และจุดอ่อนทางด้านความปลอดภัย
- ค) ผู้ใช้งานต้องไม่พยายามแก้ไขจุดอ่อนที่ต้องสงสัยออกเพื่อประโยชน์ในการตรวจสอบจากผู้ดูแลหรือผู้เชี่ยวชาญเว้นแต่จะได้รับอนุญาต

10.1.4 การเรียนรู้จากเหตุการณ์ด้านความมั่นคงปลอดภัยสารสนเทศ

ควรมีการทบทวนเหตุการณ์และจุดอ่อนทางด้านความปลอดภัย และประเภท ขนาด และต้นทุนของเหตุการณ์และการทำงานที่ผิดปกติควรจะถูกกำหนดเป็นตัวเลขและติดตาม

ประเภทของเหตุการณ์ที่ต้องทำการรายงาน

- ก) การขโมย และวินาศกรรมด้านโครงสร้างพื้นฐานของเทคโนโลยีสารสนเทศ
- ข) การเข้าถึงระบบ เครือข่ายหรือข้อมูลโดยไม่ได้รับอนุญาต (ทั้งที่สำเร็จและไม่สำเร็จ)
- ค) การเปลี่ยนแปลงระบบ เครือข่ายหรือข้อมูลโดยไม่ได้รับอนุญาต
- ง) การปฏิเสธหรือการขัดขวางบริการที่มีต่อระบบ เครือข่ายหรือข้อมูล
- จ) การทำเว็บไซต์ให้เสียหาย
- ฉ) การติดไวรัสของคอมพิวเตอร์
- ช) การสูญเสียความลับของข้อมูล (เช่น ความไม่ปลอดภัยของรหัสผ่าน, บัตรผ่านเข้าออก, อุปกรณ์บันทึกพกพา, คอมพิวเตอร์พกพา, อุปกรณ์พกพาอื่นๆ)
- ซ) การเก็บข้อมูลโดยไม่ได้รับอนุญาต (เช่น การตรวจสอบช่องโหว่, การเก็บบันทึกเหตุการณ์)
- ณ) การประมาทเลินเล่ออย่างร้ายแรงในการใช้ทรัพยากรคอมพิวเตอร์

10.1.5 การเก็บรวบรวมหลักฐาน

ต้องมีการเก็บรักษาหลักฐานสนับสนุนอื่นๆ อาทิ อีเมลล์ ผู้ดูแล การเข้าถึง ซ็อกเก็ต ไฟร์วอลล์ และระบบตรวจจับการบุกรุก และที่เกี่ยวข้องอื่นๆ โดยวิธีการเก็บรวบรวมหลักฐานควรจะสอดคล้องกับแนวปฏิบัติการจัดเก็บและจัดการสารสนเทศที่ใช้เป็นหลักฐาน

11. มุมมองด้านความมั่นคงปลอดภัยสารสนเทศของการบริหารความต่อเนื่องของธุรกิจ (Information security aspects of business continuity management)

11.1 ความต่อเนื่องด้านความมั่นคงปลอดภัยสารสนเทศ (Information security continuity)

11.1.1 การวางแผนความต่อเนื่องด้านความมั่นคงปลอดภัยสารสนเทศ

การวางแผนความต่อเนื่องทางธุรกิจ เพื่อพัฒนาและรักษาความต่อเนื่องของธุรกิจทั่วทั้งองค์กร ประกอบด้วยเทคโนโลยีสารสนเทศ การบริหารจัดการ และด้านอื่นๆ ของฝ่ายต่างๆ

- ก) การประเมินต้องคำนึงถึงกระบวนการทางธุรกิจทั้งหมด และไม่จำกัดอยู่เพียงระบบประมวลผลเท่านั้น
- ข) ควรทำการวิเคราะห์ผลกระทบทางธุรกิจและระบุเหตุการณ์ความเสี่ยงที่สามารถทำให้กระบวนการทางธุรกิจหยุดชะงักได้
- ค) ต้องคำนึงถึงด้านความมั่นคงปลอดภัยสารสนเทศในช่วงระหว่างเหตุการณ์หยุดชะงักและปฏิบัติตามแผนความต่อเนื่อง

11.1.2 การปฏิบัติเพื่อเตรียมการสร้างความต่อเนื่องด้านความมั่นคงปลอดภัยสารสนเทศ

ต้องมีการปฏิบัติตามแผนความต่อเนื่องทางธุรกิจ หากเกิดเหตุภัยพิบัติ การให้บริการทางธุรกิจที่สำคัญขององค์กรจะสามารถดำเนินการได้ภายใต้กรอบเวลาที่กำหนดไว้

ข้อพิจารณาของข้อกำหนดทางความมั่นคงปลอดภัยสารสนเทศ

- ก) สภาพแวดล้อมทางกายภาพของระบบคอมพิวเตอร์สำรองฉุกเฉินจะต้องปฏิบัติตามความมั่นคงปลอดภัยขั้นต่ำ คือ การกำหนดความรับผิดชอบในการเข้าถึงระบบคอมพิวเตอร์สำรองฉุกเฉิน

- ข) การเตรียมระบบคอมพิวเตอร์สำรองฉุกเฉินต้องมีสถาปัตยกรรมเครือข่ายเช่นเดียวกับสภาพแวดล้อมปกติ โดยที่ความสามารถในการทำงานซ้ำซ้อนอาจลดลงได้
- ค) การเตรียมระบบ ICT ต้องมีความปลอดภัยตามแนวทางการทำให้องค์กรเข้มแข็ง
- ง) ต้องมีการจัดการข้อมูลตลอดเวลาโดยผู้ควบคุมที่ถูกกำหนดไว้และผู้ใช้
- จ) ต้องมีการจัดการสื่อบันทึกโดยผู้ได้รับอนุญาต และทำการจัดเก็บในตู้ที่ถูกล็อกอย่างดี
- ฉ) ในกรณีที่มีการให้บริการจากหน่วยงานภายนอก ต้องมีเอกสารรายชื่อบุคคลผู้มีอำนาจ เพื่อที่จะสามารถเริ่มและยุติการให้บริการ

11.1.3 การพัฒนาและจัดทำแผนการบริหารความต่อเนื่องของธุรกิจรวมทั้งความมั่นคงปลอดภัยของข้อมูล

แผนการบริหารความต่อเนื่องของธุรกิจควรประกอบด้วยสิ่งต่อไปนี้

- ก) การระบุกระบวนการทางธุรกิจที่มีความสำคัญ และการใช้งานร่วมกันหรือความต่อเนื่องกันของกระบวนการเหล่านี้
 - ๑) ลำดับความสำคัญของกระบวนการต่างๆ ที่ต้องกู้กลับมา
 - ๒) การระบุความรับผิดชอบทั้งหมดและการเตรียมการสำหรับกรณีฉุกเฉิน
 - ๓) เอกสารเกี่ยวกับวิธีการกู้กระบวนการคืน เช่น Hot Site, Cold Site, ทรัพยากรที่ใช้ ฯลฯ
 - ๔) เอกสารเกี่ยวกับขั้นตอนต่างๆ ที่ได้ตกลงกันแล้ว
- ข) แผนการบริหารความต่อเนื่องของธุรกิจต้องครอบคลุมถึงความต่อเนื่องของกระบวนการทางธุรกิจและบริการที่มีความสำคัญ ซึ่งรวมถึงแต่ไม่จำกัดเฉพาะพนักงาน ข้อกำหนดการดำเนินงาน และการกู้บริการด้านคอมพิวเตอร์คืนจากภัยพิบัติ
- ค) แผนการบริหารความต่อเนื่องของธุรกิจต้องระบุผู้รับผิดชอบและหน้าที่เพื่อให้สามารถดำเนินการตามแผนได้
- ง) พนักงานควรได้รับการฝึกอบรมเกี่ยวกับขั้นตอนการกู้ระบบคืนตามที่ตกลงกัน และจะต้องทำการทดสอบเป็นประจำเพื่อให้มั่นใจว่าพนักงานรู้ว่าต้องตอบสนองอย่างไรเพื่อคงความต่อเนื่องของธุรกิจต่อไป

11.1.4 การทดสอบ การบำรุงรักษา และการประเมินแผนการบริหารความต่อเนื่องของธุรกิจ

- ก) ควรจะมีการทดสอบด้านความต่อเนื่องของธุรกิจอย่างน้อยปีละหนึ่งครั้ง
- ข) จะต้องกำหนดวิธีทดสอบก่อนการทดสอบจริง
- ค) จะต้องติดตามข้อบกพร่องที่ระบุได้ในระหว่างการทดสอบความต่อเนื่องของธุรกิจ

11.2 การเตรียมการอุปกรณ์ประมวลผลสำรอง (Redundancies)

11.2.1 สภาพความพร้อมใช้ของอุปกรณ์ประมวลผลสารสนเทศ

การเตรียมความพร้อมในการสำรองอุปกรณ์ ควรพิจารณาถึงเงื่อนไขดังนี้

- ก) ระบบต้องปฏิบัติตามกฎหมาย ข้อบังคับ และข้อผูกพันตามสัญญาเกี่ยวกับลูกค้า
- ข) ระบบมีระดับการวิเคราะห์ผลกระทบทางธุรกิจสูง
- ค) ระบบที่พึ่งพาระบบอื่นที่มีระดับการวิเคราะห์ผลกระทบทางธุรกิจสูง

11.2.2ตามข้อจำกัดทางภูมิศาสตร์ ความต้องการทางธุรกิจ และข้อจำกัดทางธุรกิจที่มีอยู่ การทำงานชุดสำรองพร้อมใช้ควรพิจารณาถึงสิ่งเหล่านี้

- ก) ความซ้ำซ้อนในการบริหารจัดการพลังงาน
- ข) ความซ้ำซ้อนในการเชื่อมโยงเครือข่ายสู่สภาพแวดล้อมภายนอก
- ค) ความซ้ำซ้อนในการเชื่อมโยงเครือข่ายภายใน
- ง) ความซ้ำซ้อนในการคำนวณ
- จ) ความซ้ำซ้อนในการเก็บรักษา

12. ความสอดคล้อง (Compliance)

12.1ความสอดคล้องกับความต้องการด้านกฎหมายและในสัญญาจ้าง(Compliance with legal and contractual requirements)

12.1.1 การระบุกฎหมายและความต้องการในสัญญาจ้างที่เกี่ยวข้อง

- ก) เจ้าของระบบต้องมั่นใจว่าระบบของตนเป็นไปตามข้อกำหนดของกฎหมายหรือ ระเบียบข้อบังคับของหน่วยงานที่กำกับดูแลในประเทศนั้นๆ
- ข) เจ้าของระบบต้องระบุความต้องการทั้งหมดที่เกี่ยวข้องกับข้อกำหนดกฎหมาย ระเบียบข้อบังคับ สัญญาจ้าง เป็นลายลักษณ์อักษร และปรับปรุงให้เป็นปัจจุบันเสมอ
- ค) เจ้าของระบบแต่ละรายต้องปฏิบัติตามข้อกำหนดในสัญญาที่ทำกับลูกค้า และข้อตกลงเกี่ยวกับระดับการให้บริการที่ให้แกลูกค้า

12.1.2 สิทธิในทรัพย์สินทางปัญญา

ต้องมีการควบคุมและมีขั้นตอนปฏิบัติที่เหมาะสม สอดคล้องกับกฎหมาย ระเบียบข้อบังคับ ในการใช้งานผลิตภัณฑ์ซอฟต์แวร์ที่มีกรรมสิทธิ์ที่ถูกต้อง

12.1.3 การป้องกันบันทึกต่างๆ

บันทึกต่างๆ ที่มีความสำคัญขององค์กรต้องได้รับการป้องกันจากการสูญหาย การทำลาย และการปลอมแปลง

12.1.4 ความเป็นส่วนตัวและการป้องกันข้อมูลส่วนบุคคล

ข้อมูลที่เป็นส่วนบุคคลที่องค์กรเก็บหรือดูแลไว้ ต้องมีการดำเนินการให้สอดคล้องกับกฎหมาย และระเบียบข้อบังคับที่เกี่ยวข้อง

12.1.5 มาตรการการเข้ารหัสข้อมูล

ต้องกำหนดให้มีแนวทางการปฏิบัติในการเข้ารหัสข้อมูลขององค์กร ให้สอดคล้องกับระดับชั้นความลับของข้อมูล และระเบียบข้อบังคับที่เกี่ยวข้องทั้งหมด

12.2 การทบทวนความมั่นคงปลอดภัยสารสนเทศ (Information security reviews)

12.2.1 การทบทวนด้านความมั่นคงปลอดภัยของข้อมูลโดยอิสระ

- ก) จะต้องมีการตรวจสอบความมั่นคงปลอดภัยของข้อมูลอย่างน้อยปีละครั้งเพื่อหาจุดที่ไม่เป็นไปตามมาตรฐาน
- ข) ผู้ตรวจสอบที่ได้รับมอบหมายให้ทำการตรวจสอบความมั่นคงปลอดภัยของข้อมูลจะต้องไม่เป็นผู้ตรวจสอบงานของตนเอง

12.2.2 การปฏิบัติให้เป็นไปตามนโยบายและมาตรฐานด้านความปลอดภัย

- ก) ผู้บังคับบัญชาต้องมีความรับผิดชอบในการดูแล และกำกับการทำงานของพนักงานในทีม เพื่อให้เป็นไปตามนโยบาย ขั้นตอน และมาตรฐานด้านความปลอดภัยที่เกี่ยวข้อง ในกรณีที่เกิดเหตุละเมิดด้านความมั่นคงปลอดภัยจากการปฏิบัติงานของทีมงาน ให้ดำเนินการร้องขอ ให้ทำการสอบสวน เพื่อให้เข้าสู่ขั้นตอนของกระบวนการแก้ไขปัญหา โดยอ้างอิงตามเอกสาร ขั้นตอนปฏิบัติในการแก้ไข Corrective Action Procedure
- ข) ผู้บังคับบัญชาต้องมีหน้าที่รับผิดชอบในการปฏิบัติตามข้อที่เกี่ยวข้องในนโยบายความมั่นคงปลอดภัย

12.2.3 การตรวจสอบความสอดคล้องทางเทคนิค

ต้องมีการประเมินเครือข่ายและมาตรการความมั่นคงปลอดภัยของระบบสารสนเทศ อย่างสม่ำเสมออย่างน้อยปีละ ๑ ครั้ง โดยบุคลากรทางเทคนิคและด้านความปลอดภัยที่เหมาะสม เพื่อตรวจสอบการควบคุมด้านความปลอดภัยต่างๆ ให้เพียงพอต่อปัจจัยเสี่ยงในปัจจุบัน

13. การบริหารจัดการความเสี่ยง (Risk management)

13.1 แนวปฏิบัติในการตรวจสอบและประเมินความเสี่ยง (Information security risk assessment)

13.1.1 ระบุความเสี่ยงและผลกระทบของความเสี่ยงให้สอดคล้องตามแผนบริหารความเสี่ยงของหน่วยงานเพื่อการตรวจสอบและประเมินความเสี่ยงนั้น ผลที่ได้จากระเบียบวิธีการประเมินความเสี่ยงสามารถนำมาเปรียบเทียบและทำซ้ำได้

- ก) ความเสี่ยงที่เกิดจากการลักลอบเข้าทางระบบปฏิบัติการเพื่อยึดครองเครื่องคอมพิวเตอร์แม่ข่ายผ่านระบบอินเทอร์เน็ต (Internet)
- ข) ความเสี่ยงที่เกิดจากการลักลอบเข้าเชื่อมโยงกับระบบเครือข่ายไร้สายโดยไม่ได้รับอนุญาต
- ค) ความเสี่ยงที่เกิดจากเครื่องมือด้านเทคโนโลยีสารสนเทศ หรือระบบเครือข่ายเกิดการขัดข้องระหว่างการใช้งาน
- ง) ความเสี่ยงที่เกิดจากการลงบันทึกเข้า (Login) สารสนเทศที่สำคัญผ่านระบบเครือข่ายของผู้ใช้บริการคนเดียวกันมากกว่าหนึ่งจุด
- จ) ความเสี่ยงที่เกิดจากการลักลอบใช้รหัสผ่าน (Password) ของผู้อื่นโดยไม่ได้รับอนุญาต

13.1.2 กำหนดวิธีการในการตรวจสอบและประเมินความเสี่ยงและความรุนแรงของผลกระทบที่เกิดจากความเสี่ยงนั้น

13.2 การตรวจสอบและประเมินความเสี่ยง

ให้คำนึงถึงองค์ประกอบ ดังต่อไปนี้

13.2.1 ความรุนแรงของผลกระทบที่เกิดจากความเสี่ยงที่ระบุ

13.2.2 ภัยคุกคามหรือสิ่งนี้อาจก่อให้เกิดเหตุการณ์ที่ระบุรวมถึงความเป็นไปได้ที่จะเกิดขึ้น

13.2.3 จุดอ่อนหรือช่องโหว่ที่อาจถูกใช้ในการก่อให้เกิดเหตุการณ์ที่ระบุ

13.3 ดำเนินการตรวจสอบและประเมินความเสี่ยงที่อาจเกิดขึ้นกับระบบสารสนเทศของหน่วยงาน

13.3.1 เพื่อให้หน่วยงานได้ทราบถึงระดับความเสี่ยง และระดับความปลอดภัยสารสนเทศ อย่างน้อยปีละ ๑ ครั้ง โดยผู้ตรวจสอบภายในของหน่วยงาน ทั้งนี้ ผู้ตรวจต้องไม่มีส่วนเกี่ยวข้องและไม่มีส่วนได้ส่วนเสียกับงานที่ต้องการตรวจ และมีความชำนาญในการตรงประเมินความเสี่ยงระบบสารสนเทศ

13.3.2 ในกรณีที่หน่วยงานไม่มีผู้ตรวจสอบภายในหรือผู้ตรวจสอบภายในไม่มีความชำนาญในการประเมินความเสี่ยงระบบสารสนเทศ ให้ประเมินความเสี่ยงโดยผู้ตรวจประเมินจากภายนอก อย่างน้อยปีละ ๑ ครั้ง

13.4 เครื่องหรือโปรแกรมคอมพิวเตอร์ซึ่งทำงานให้บริการในระบบเครือข่ายแก่ลูกค้า (ซึ่งให้บริการผู้ใช้อีกหนึ่ง)

เครื่องคอมพิวเตอร์ที่ทำหน้าที่เป็นเครื่องแม่ข่ายนี้ควรมีประสิทธิภาพสูง มีความเสถียร สามารถให้บริการแก่ผู้ใช้ได้เป็นจำนวนมาก